Evidencias técnicas de las pruebas

Capturas y archivos de resultados de las pruebas de integración, seguridad y rendimiento

Proyecto	FarmaClick - Sistema de gestión para farmacias - Módulo administrativo
Cliente / contraparte	MediFarm
Equipo	D-Software: Alejandro Fuentes Navarrete, Víctor Rubilar Inostroza, Robert González Muñoz
Documento asociado	DOC-08 Plan de Pruebas y Evidencias, versión 1.3 (secciones 3, 4, 6 y 7)
Fecha de las ejecuciones	17 de octubre de 2026 (réplica local) y 20 y 21 de octubre de 2026 (dev y producción), dentro del Sprint 5 (línea base del módulo administrativo)
Ejecutadas por	Víctor Rubilar Inostroza y Alejandro Fuentes Navarrete
Entornos	Local (réplica de la rama dev), Dev (Supabase farmaclick-dev) y Producción (https://farmaclick-medifarm.duckdns.org, Supabase farmaclick-prod)

Convención de nombres

Capturas: CÓDIGO-DEL-CASO_AAAAMMDD[_entorno][_orden o contenido].png, donde AAAAMMDD es la fecha de la ejecución que se evidencia. Cuando un caso tiene varias capturas, el sufijo numérico indica el paso y la letra, la parte del mismo paso. Las capturas que no pertenecen a un caso llevan el prefijo CI_ (integración continua), PREP_ (preparación) u OBS_ (observaciones). Las capturas de la réplica local conservan los nombres con que se entregaron. Los archivos de texto y reportes se listan en la sección 8.

Índice de evidencias por caso

Caso	Prueba	Entorno	Resultado	Figuras
PREP	Carga de variables y conectividad	Dev	-	Fig. 1
CP-INT-01 a 08 y CP-SEG-01 a 09	Prueba de humo y seguridad (script)	Local	17 aprobadas, 2 informativas	Fig. 2
		Dev (antes)	16 aprobadas, 3 informativas (hallazgo CP-SEG-09)	Fig. 3
		Dev (después)	19 aprobadas, 0 fallidas	Fig. 4
		Producción	19 aprobadas, 0 fallidas	Fig. 5
Secciones 3 y 4.1	Integración continua, ejecución n.º 18	GitHub Actions	Aprobado (6 jobs en verde)	Figs. 6 a 12

Caso	Prueba	Entorno	Resultado	Figuras
HU-57	Carga con 20 usuarios (k6)	Dev	Aprobado: p(95) 705,35 ms; 0 % de errores	Figs. 13 a 14
		Producción	Aprobado: p(95) 744,51 ms; 0 % de errores	Figs. 15 a 18
CP-SEG-10	Fuerza bruta en el login	Dev	Aprobado: 429 en el intento 21	Figs. 19 a 68
CP-SEG-11	Escaneo con OWASP ZAP	Producción	Aprobado: 0 alto, 1 medio, 5 bajo, 5 informativas	Figs. 20 a 22
CP-SEG-12	Dependencias (npm audit)	Backend y frontend	Aprobado con observación: 2 moderadas (backend), 0 (frontend)	Figs. 23 a 69
CP-SEG-13	RLS y privilegios de la base	Dev	Aprobado: 0, 0, 39 y 3 tareas activas	Figs. 25 a 28
		Producción	Aprobado: 0, 0, 39 y 3 tareas activas	Figs. 29 a 32
CP-SEG-14	Secretos en el repositorio	GitHub Actions	Aprobado: limpio en verde; prueba negativa en rojo	Fig. 7 y Figs. 33 a 39
CP-SEG-15	HTTPS y certificado	Producción	Aprobado: SSL Labs A-; solo puerto 443	Figs. 40 a 55
CP-SEG-16	Exposición de la VM de producción	Producción	Aprobado: sin respuesta; solo regla desde 10.0.0.0/16	Figs. 56 a 57
OBS-01	Estado de las VM	Dev y producción	Observación: actualizaciones pendientes	Figs. 58 a 59
Réplica local (17-10-2026)	Jobs de CI: esquema, backend, frontend y seguridad (CP-SEG-14)	Local	Aprobado: 39 tablas con RLS; 61 pruebas; build; 0 secretos	Figs. 60 a 63
	Humo y seguridad (CP-INT-01 a 08, CP-SEG-01 a 09), CP-SEG-07 y CP-SEG-10	Local	Aprobado: 17 y 2 informativas por API; 19 de 19 con Nginx corregido; 429 en el intento 21	Figs. 64 a 68
	CP-SEG-12, CP-SEG-13 y HU-57 (k6 referencial)	Local	Aprobado: 2 moderadas; 0, 0 y 39; p(95) 15,04 ms	Figs. 69 a 71

1. Preparación del entorno

Antes de las pruebas automatizadas se cargan en la consola las direcciones de dev y de producción y las credenciales de prueba (las claves se ingresan sin que se muestren en pantalla).



Figura 1 - PREP_variables_y_conectividad_20261020.png

Carga de las variables de entorno y consulta a /api/health de dev, que responde { "ok": true }. Las pruebas contra producción se ejecutan con https:// (Figura 5).

2. Integración de la API: prueba de humo y seguridad (CP-INT-01 a 08 y CP-SEG-01 a 09)

El script humo_y_seguridad.sh ejecuta 19 comprobaciones contra el entorno indicado: CP-INT-01 a 08 (humo) y CP-SEG-01 a 09 (autenticación, autorización, entradas maliciosas y cabeceras de seguridad).

Resultado esperado: 19 aprobadas y 0 fallidas.

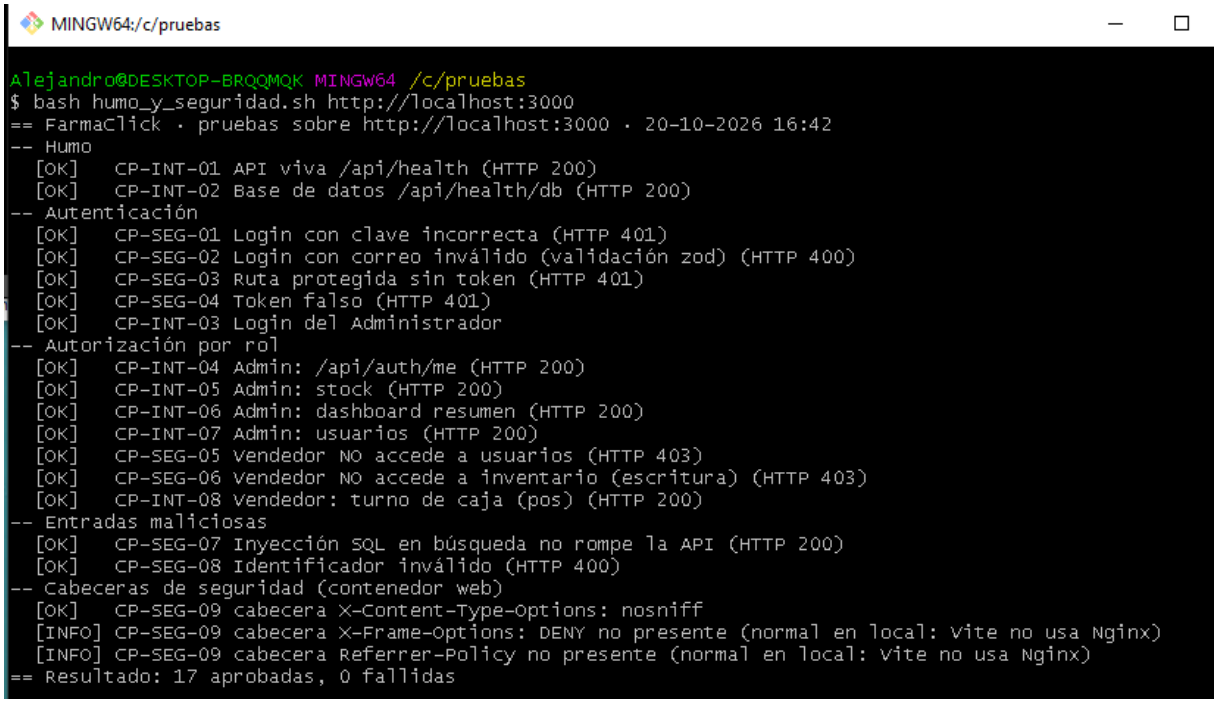


Figura 2 - CP-INT-01a08_SEG-01a09_local_20261020.png

Entorno local (http://localhost:3000, 20-10-2026 16:42): 17 aprobadas, 0 fallidas. Las comprobaciones de X-Frame-Options y Referrer-Policy salen como informativas porque en local el servidor de desarrollo (Vite) no usa Nginx.

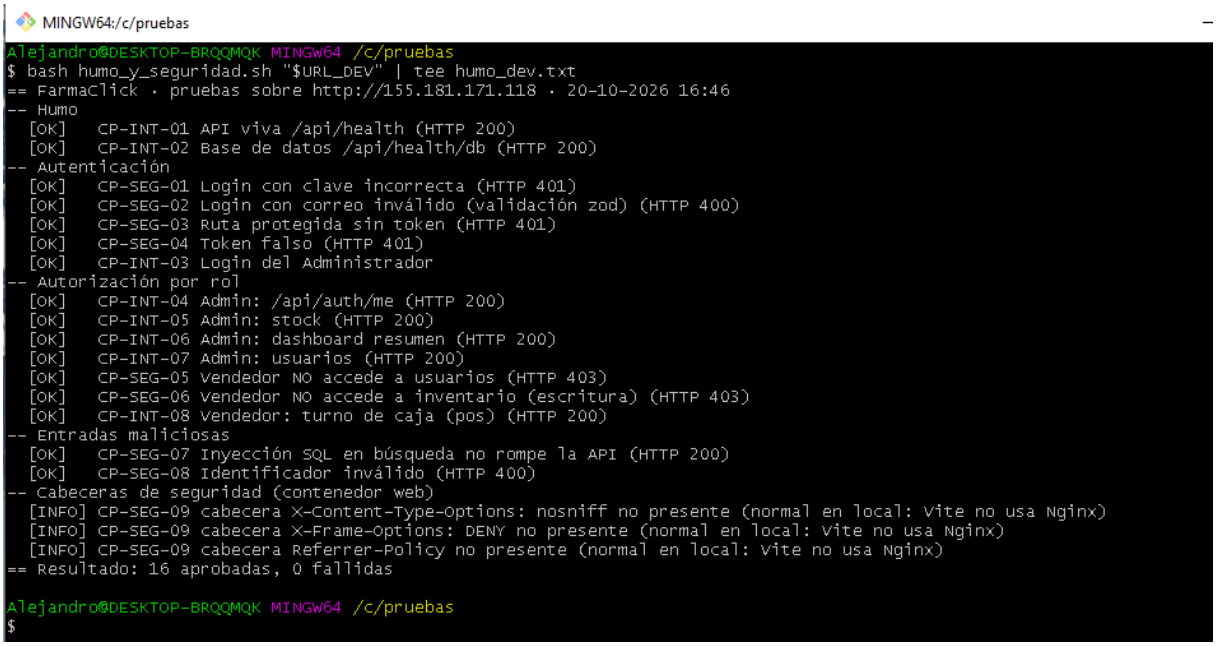


Figura 3 - CP-INT-01a08_SEG-01a09_dev_antes_20261020.png

Dev antes de la corrección (20-10-2026 16:46): 16 aprobadas, 0 fallidas y 3 informativas. Las cabeceras X-Content-Type-Options, X-Frame-Options y Referrer-Policy no llegaban en la página principal: hallazgo de CP-SEG-09. Se corrige nginx.conf (las cabeceras se repiten en /assets/ e index.html, porque Nginx no hereda add_header entre bloques location), se sube a GitHub y se despliega en dev. Salida en humo_dev_antes_20261020.txt.

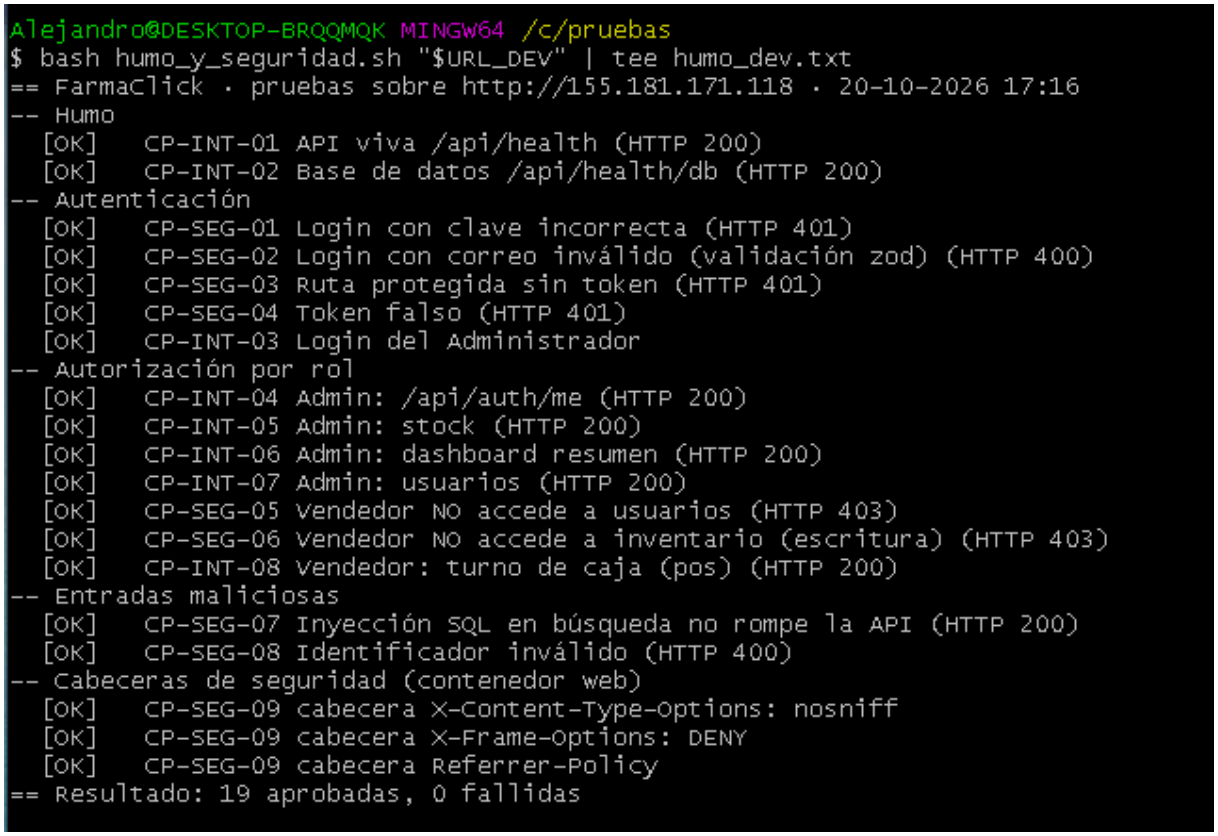


Figura 4 - CP-INT-01a08_SEG-01a09_dev_20261020.png

Dev después del despliegue de la corrección (20-10-2026 17:16): 19 aprobadas, 0 fallidas; las tres cabeceras de CP-SEG-09 presentes. Salida en humo_dev.txt.

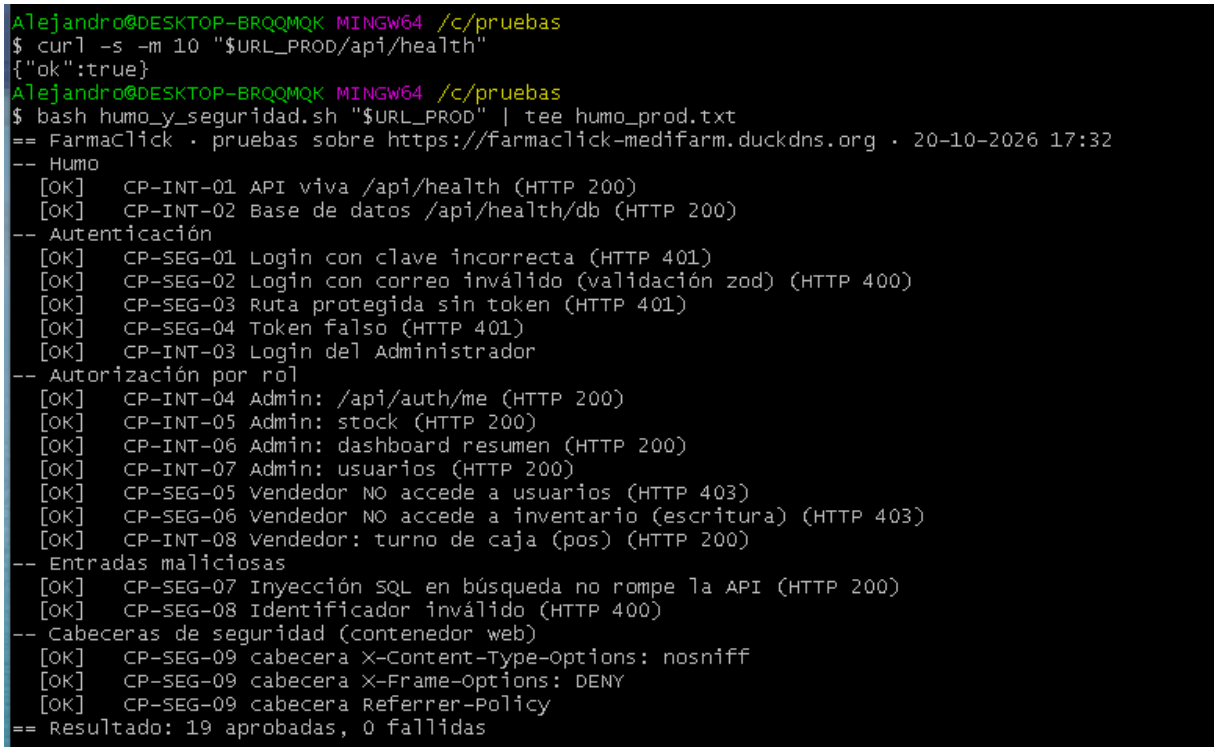


Figura 5 - CP-INT-01a08_SEG-01a09_prod_20261020.png

Producción (https://farmaclick-medifarm.duckdns.org, 20-10-2026 17:32): 19 aprobadas, 0 fallidas. Antes de la ejecución, consulta a /api/health con { "ok": true }. Salida en humo_prod.txt.

3. Integración continua (secciones 3 y 4.1 del plan)

Ejecución n.º 18 del flujo CI sobre la rama main ("Repite las cabeceras de seguridad en /assets/ e index.html"), la misma que despliega la corrección de CP-SEG-09. Los seis jobs terminan en verde en 2 min 47 s.

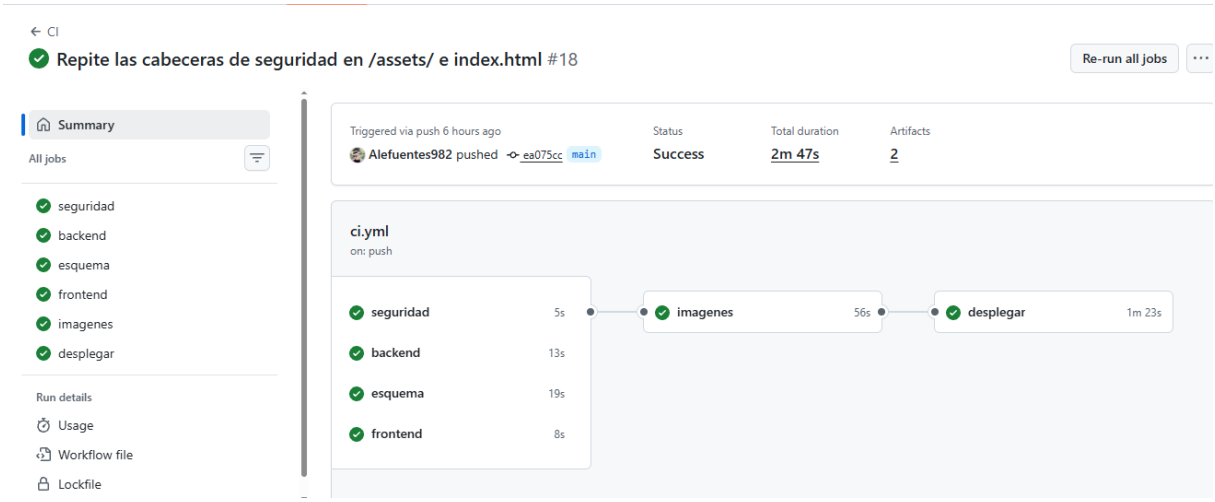


Figura 6 - `CI_ejecucion_20261020.png`

Resumen de la ejecución: estado Success. Los jobs seguridad, backend, esquema y frontend corren en paralelo y, si todos pasan, siguen imágenes y desplegar.

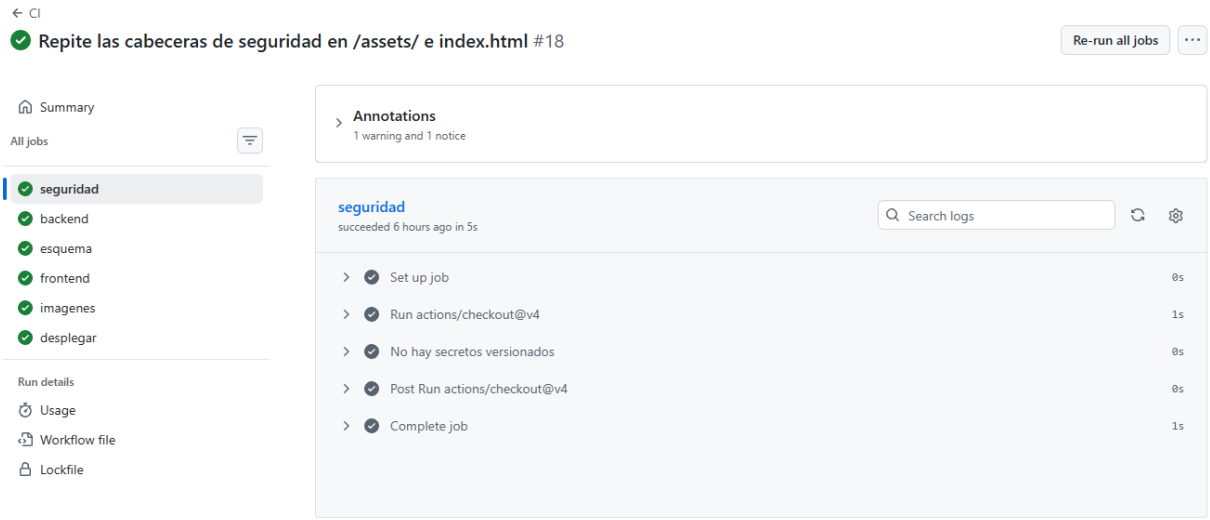


Figura 7 - `CP-SEG-14_20261020_1.png`

Job seguridad (5 s): el paso "No hay secretos versionados" termina bien. Es la evidencia del caso CP-SEG-14 con el repositorio limpio.

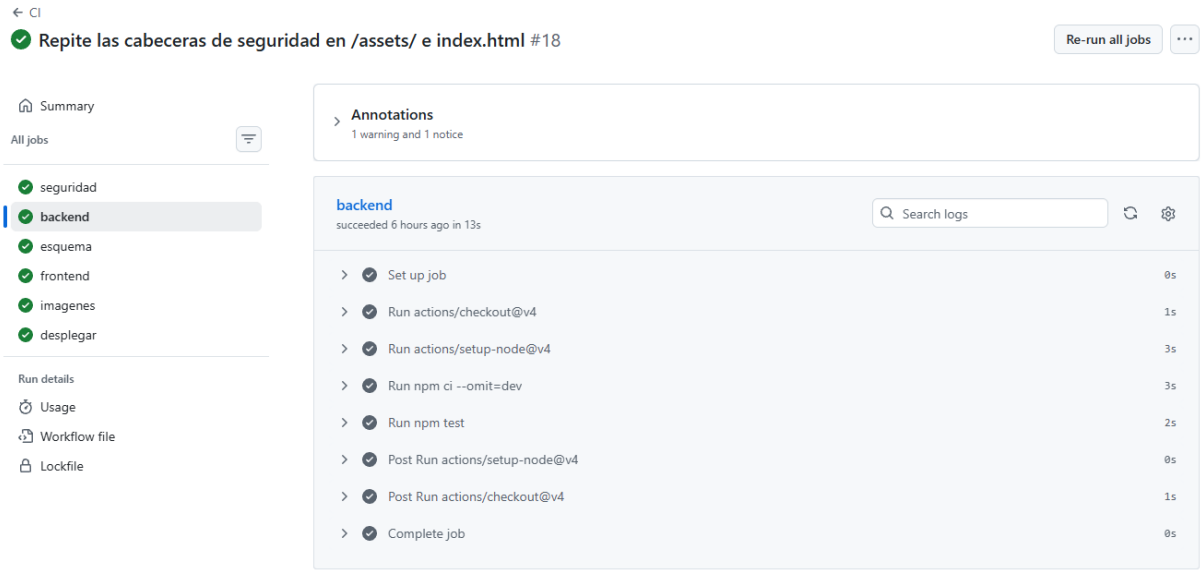


Figura 8 - `CI_backend_20261020.png`
Job backend (13 s): instalación de dependencias y paso "Run npm test" (pruebas unitarias) aprobado.

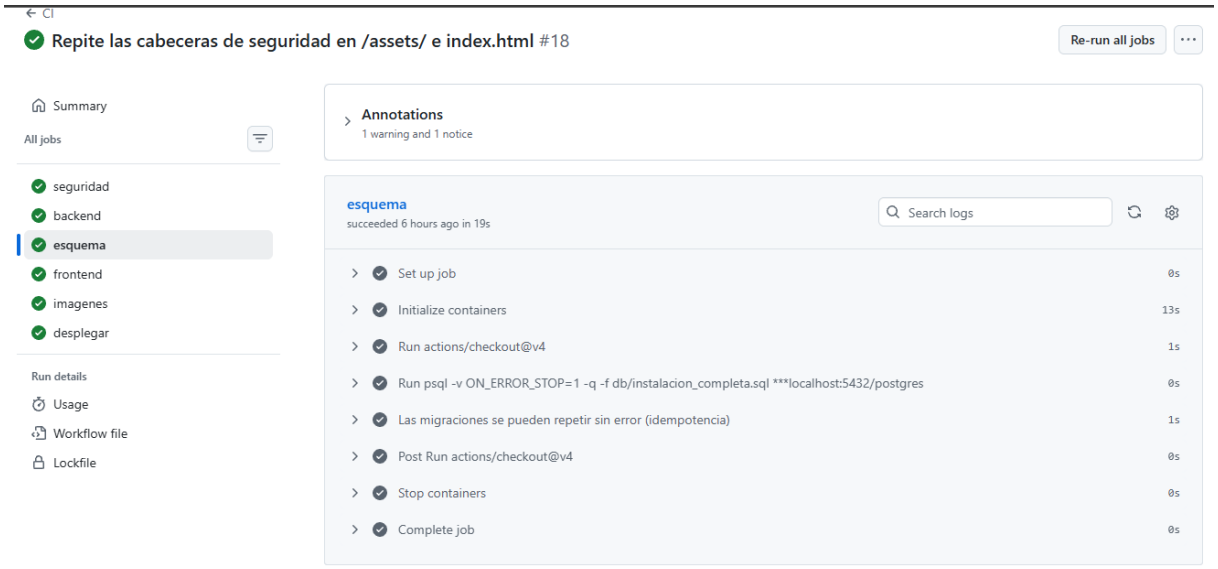


Figura 9 - `CI_esquema_20261020.png`
Job esquema (19 s): se levanta PostgreSQL 16, se instala db/instalacion_completa.sql y se comprueba que las migraciones se pueden repetir sin error (idempotencia).

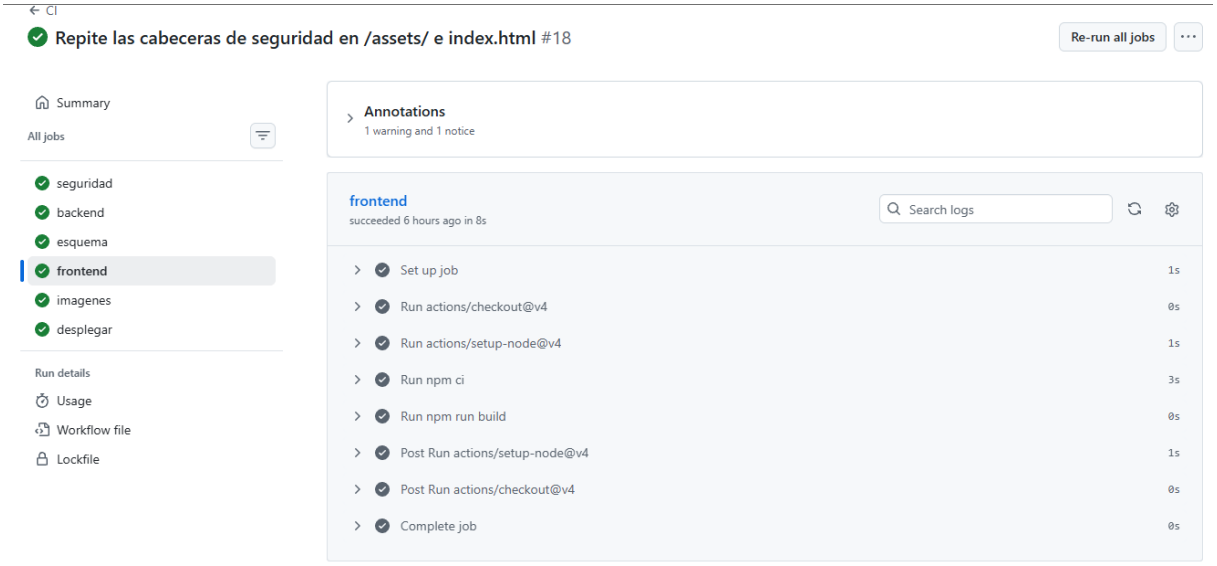


Figura 10 - `CI_frontend_20261020.png`
Job frontend (8 s): instalación de dependencias y construcción (npm run build) en verde.

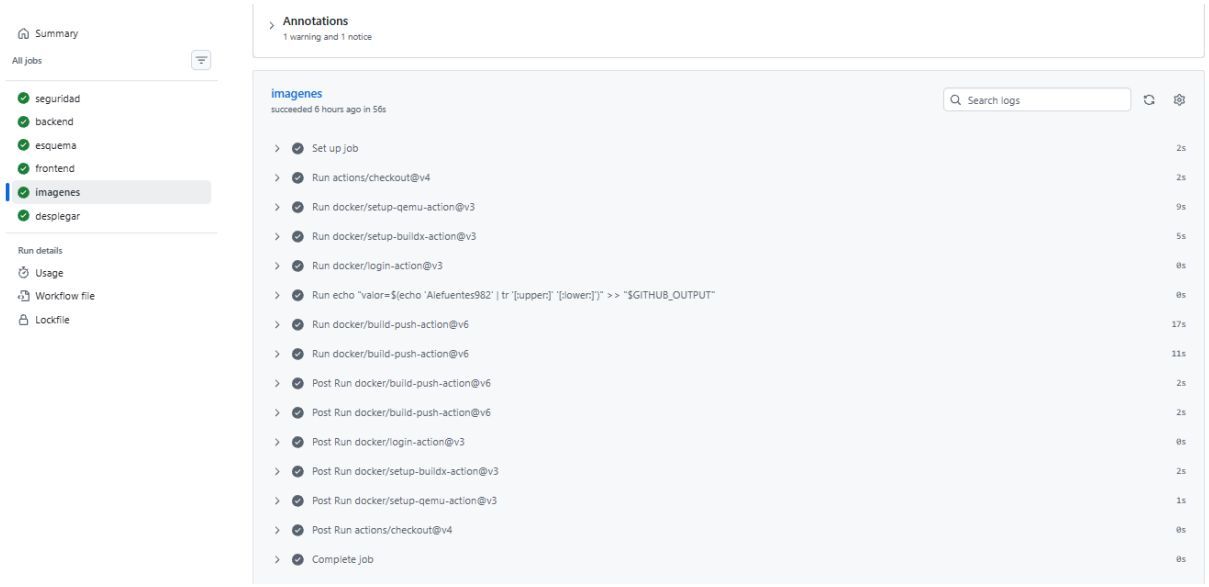


Figura 11 - `CI_imagenes_20261020.png`
Job imágenes (56 s): construcción y publicación de las imágenes Docker.

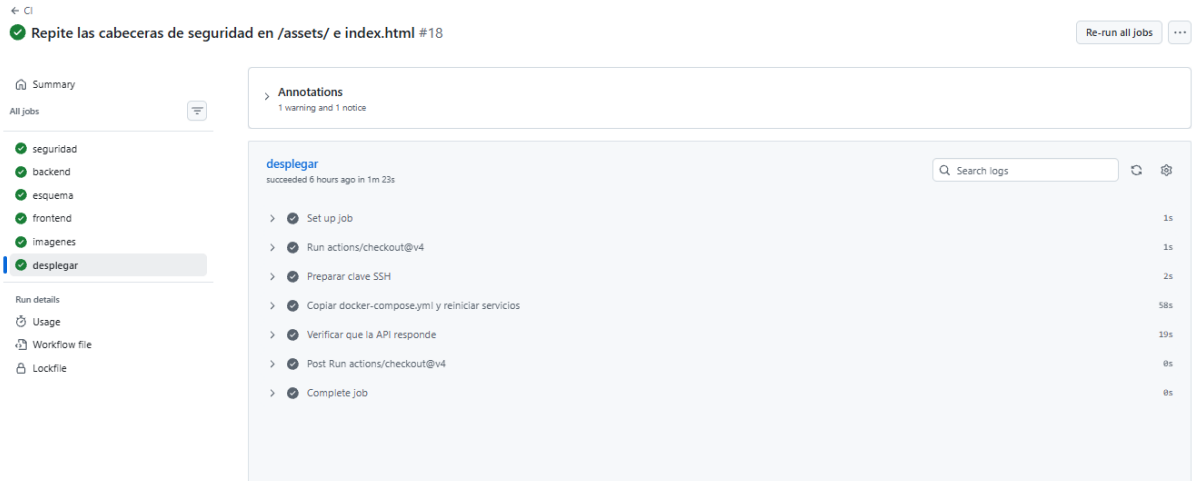


Figura 12 - `CI_desplegar_20261020.png`

Job desplegar (1 min 23 s): preparación de la clave SSH, copia de docker-compose.yml, reinicio de los servicios y verificación de que la API responde.

4. Rendimiento con k6 (HU-57)

Escenario de carga_k6.js: subida a 10 usuarios en 30 s, 20 usuarios durante 1 min y bajada en 30 s; cada iteración consulta la salud de la base, el stock, la búsqueda de productos y el dashboard. Criterios: http_req_duration p(95) < 800 ms y http_req_failed < 1 %. Los resúmenes completos están en k6_dev.txt y k6_prod.txt.

Dev

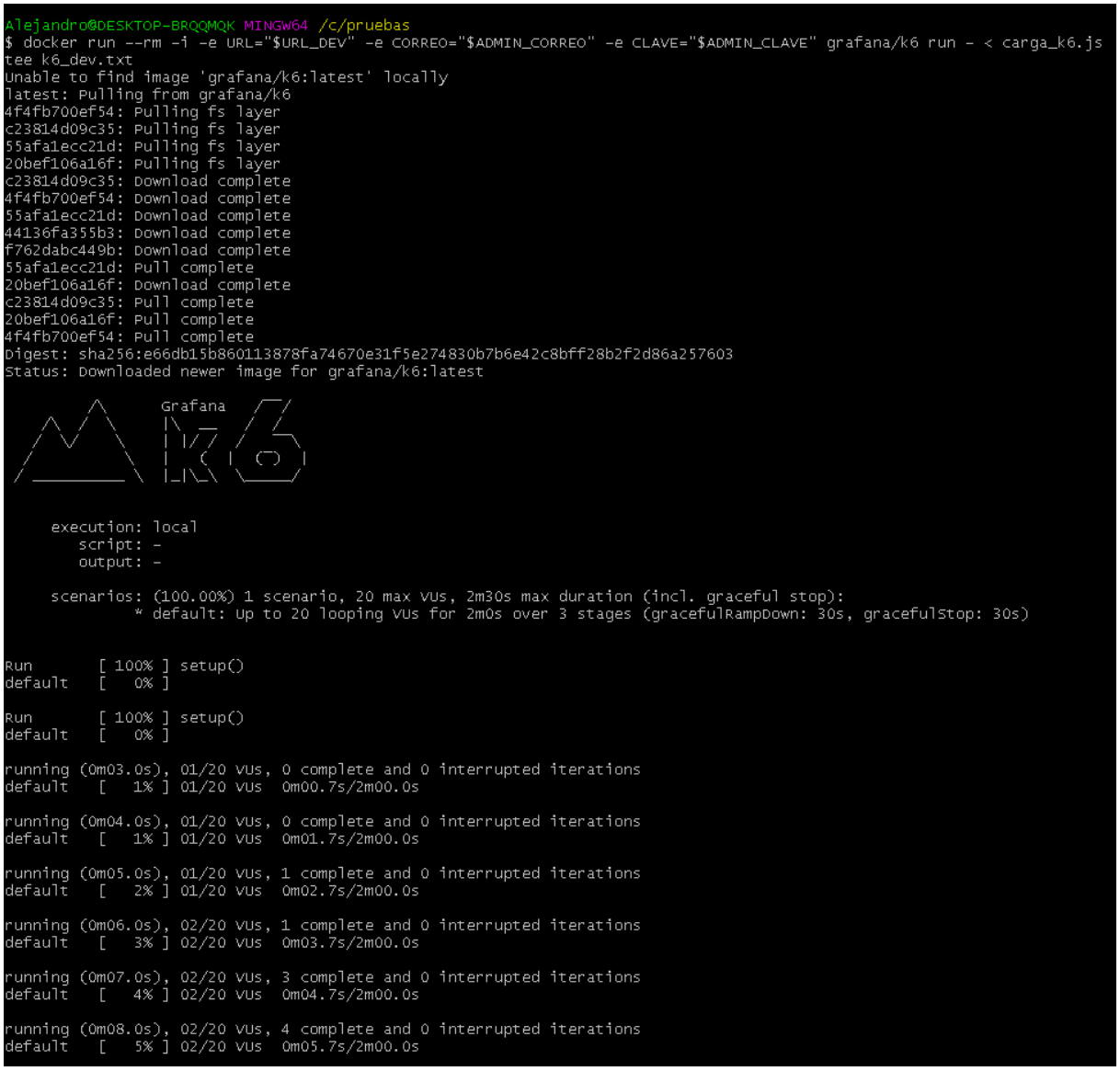


Figura 13 - HU-57_k6_inicio_dev_20261020.png

Inicio de la prueba contra dev: descarga de la imagen grafana/k6 y escenario de hasta 20 usuarios virtuales en 3 etapas.

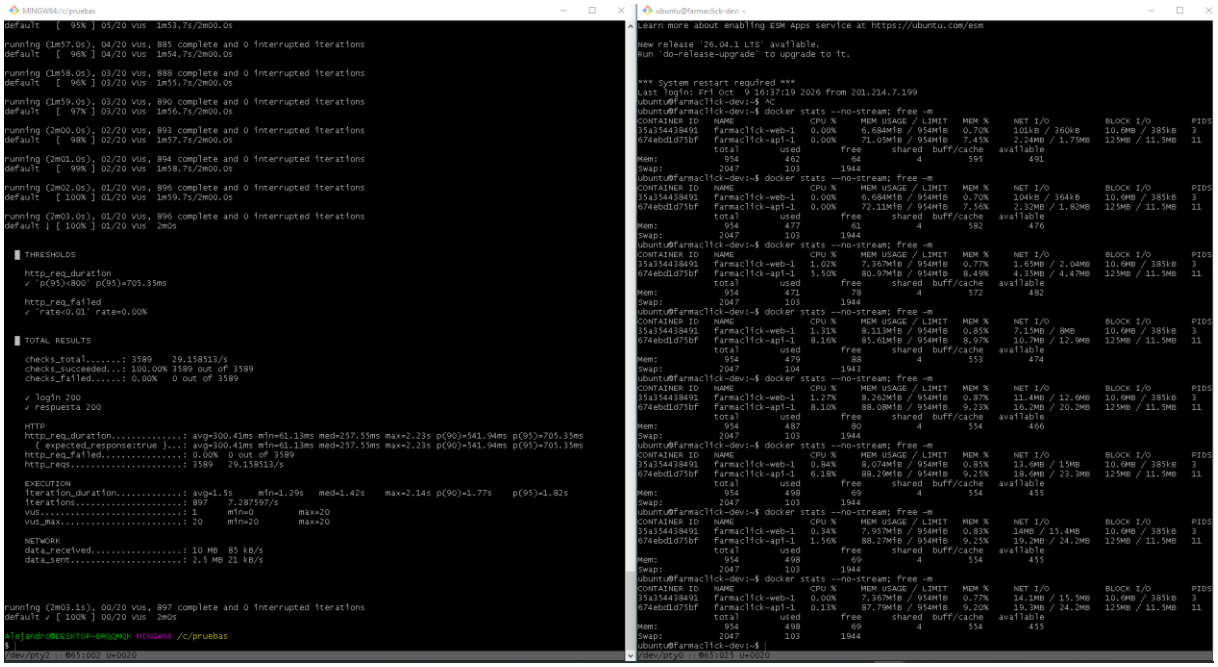


Figura 14 - HU-57_k6_resumen_docker_stats_dev_20261020.png

Izquierda: resumen final de k6 en dev, con p(95) = 705,35 ms (meta < 800 ms) y 0,00 % de solicitudes fallidas (0 de 3.589). Derecha: docker stats y free -m en la VM de dev durante la prueba (CPU máxima del contenedor API 8,16 %; memoria máxima 88,29 MiB, 9,25 %; memoria del servidor en uso 498 de 954 MiB).

Producción

Ejecutada fuera del horario de uso, a través del balanceador y con HTTPS.

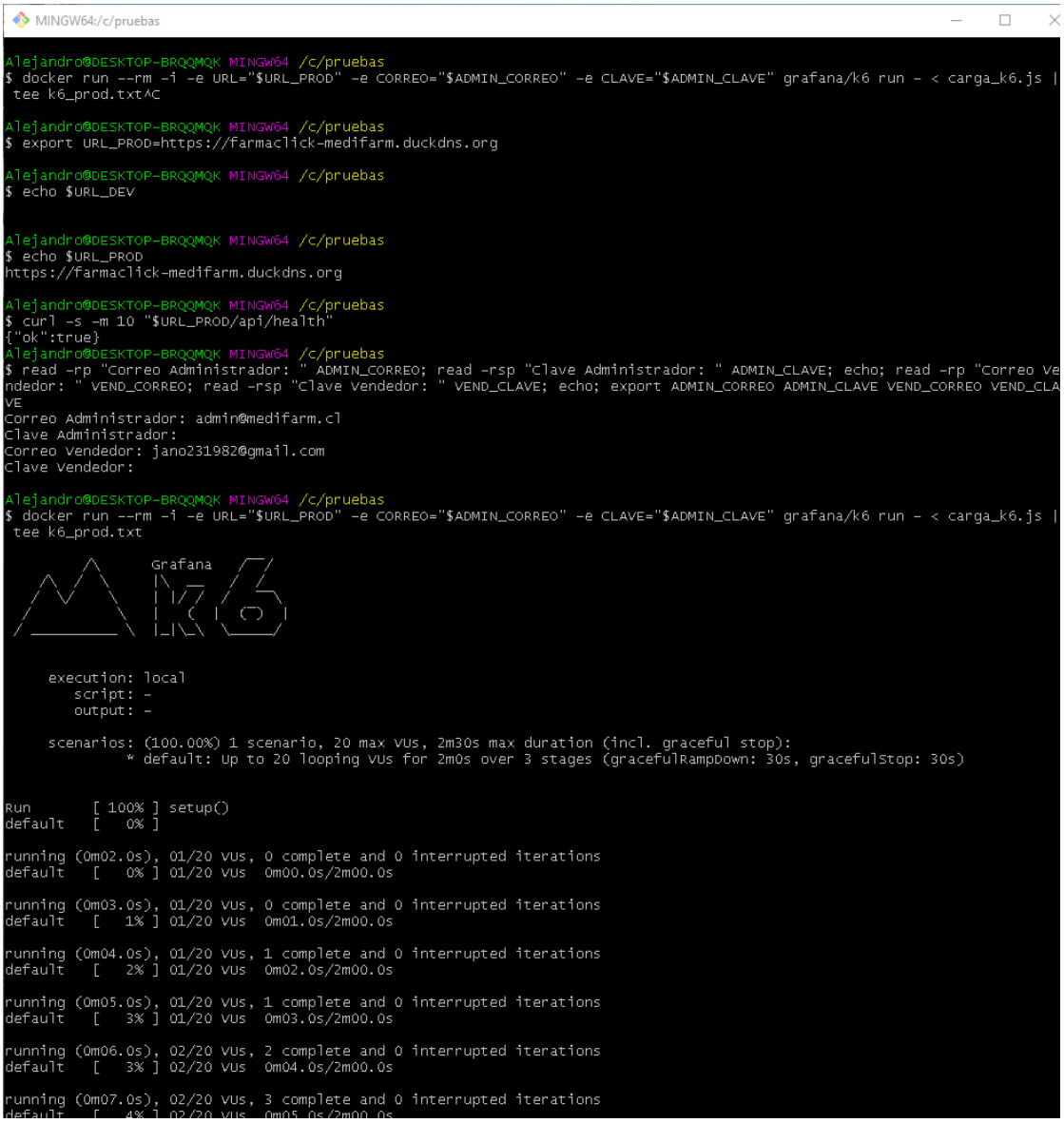


Figura 15 - HU-57_k6_inicio_prod_20261020.png

Inicio de la prueba contra producción. Se verifica /api/health ({ "ok": true }) y se lanza la prueba.

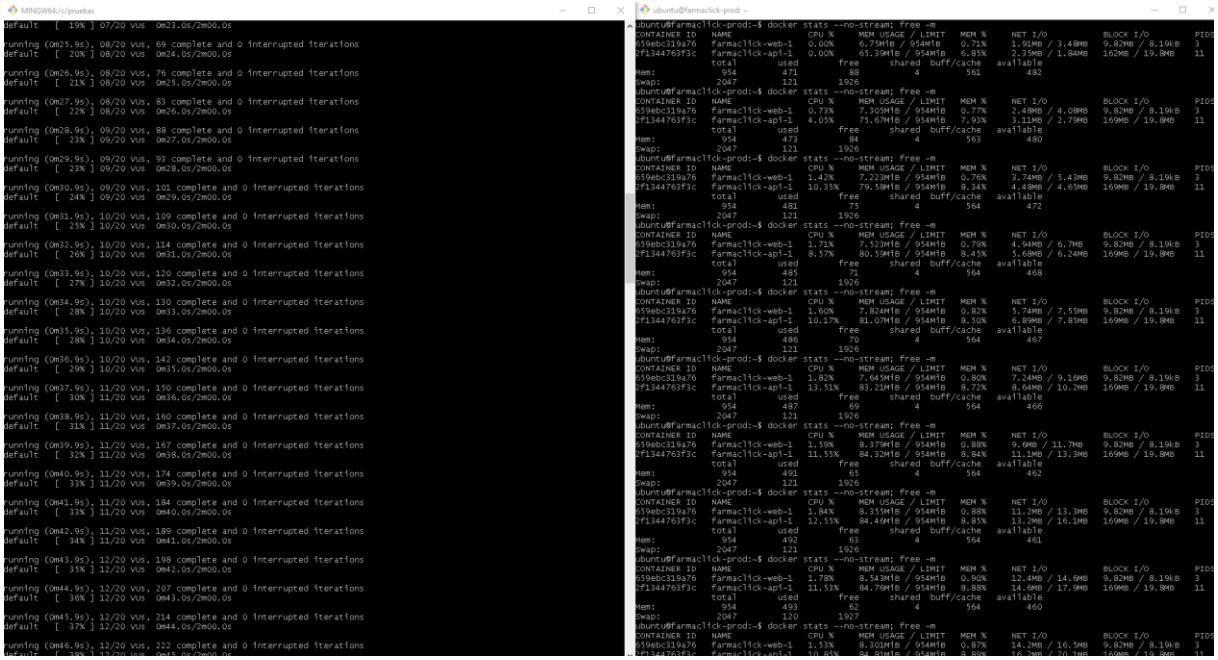


Figura 16 - HU-57_k6_ejecucion_docker_stats_prod_20261020.png

Prueba en curso: a la izquierda el avance de k6 (usuarios virtuales e iteraciones completas) y a la derecha docker stats y free -m en la VM de producción.

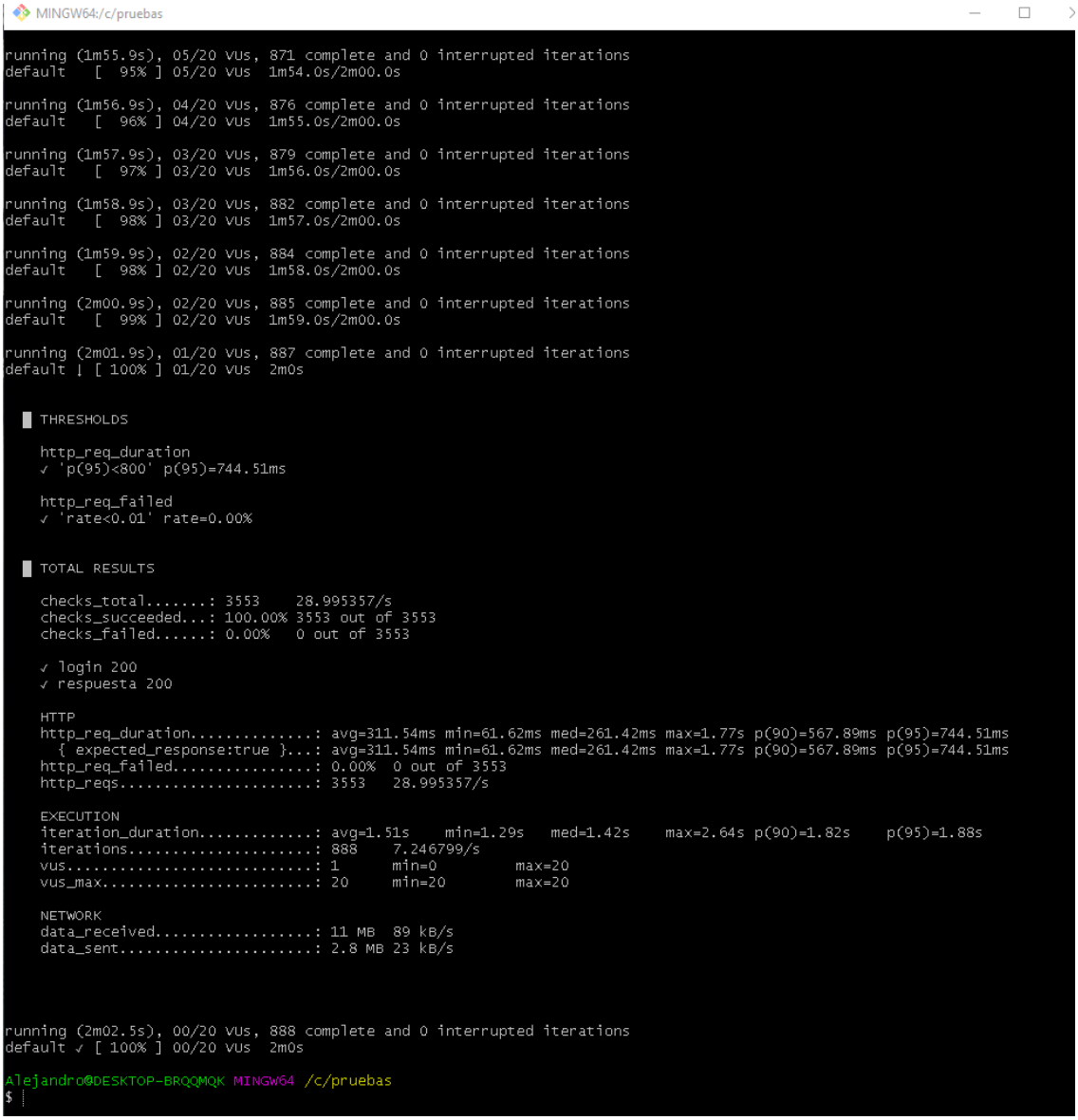


Figura 17 - HU-57_k6_resumen_prod_20261020.png

Resumen final en producción: p(95) = 744,51 ms (meta < 800 ms) y 0,00 % de solicitudes fallidas (0 de 3.553); 888 iteraciones y 29,0 solicitudes por segundo.

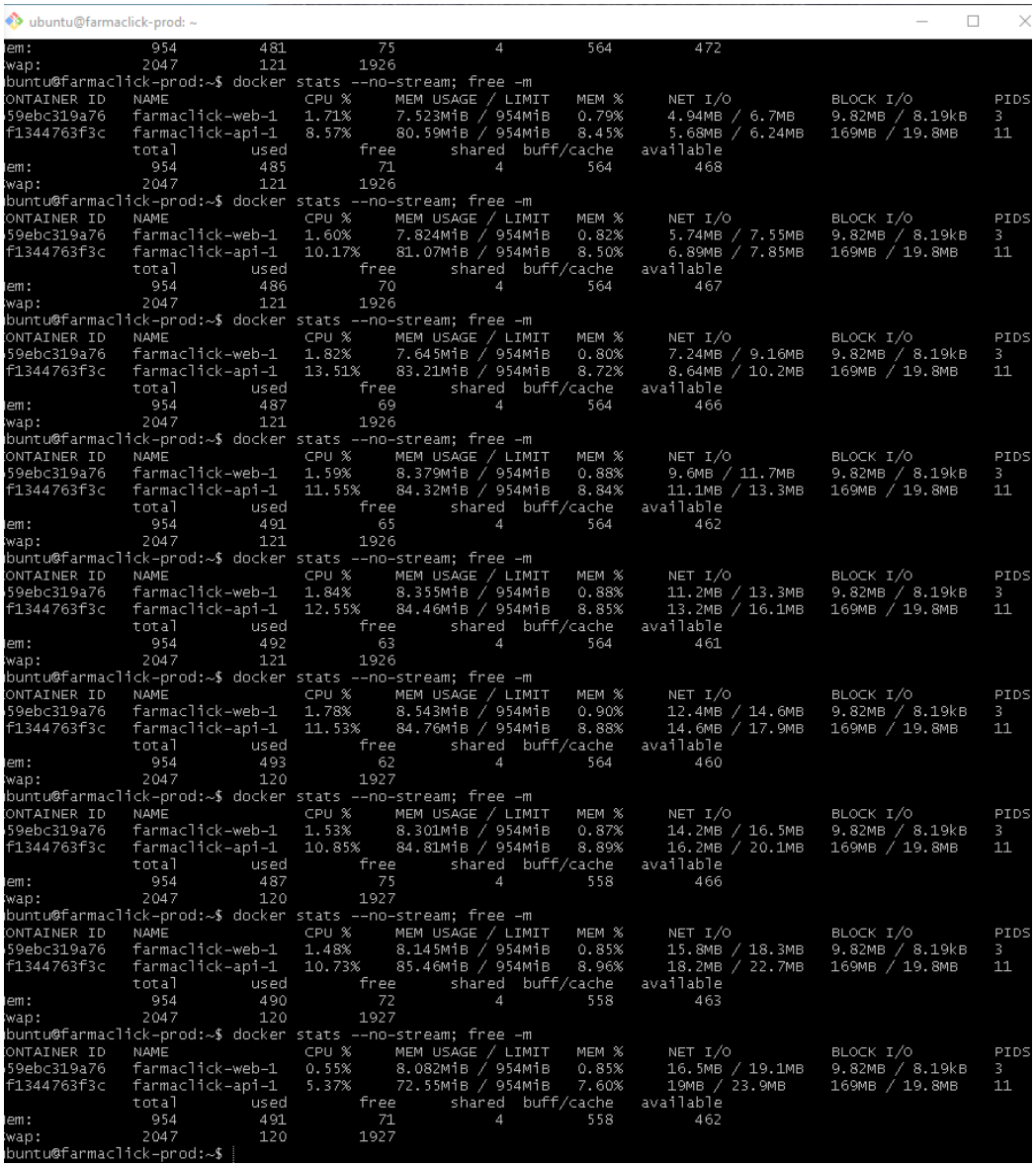


Figura 18 - HU-57_docker_stats_prod_20261020.png

docker stats y free -m en la VM de producción hacia el final de la prueba: contenedor API con CPU máxima de 13,51 % y memoria de 85,46 MiB (8,96 %); memoria del servidor en uso 493 de 954 MiB.

5. Pruebas de seguridad (HU-58)

Evidencias de CP-SEG-10 a CP-SEG-16. CP-SEG-01 a 09 están en la sección 2.

CP-SEG-10 - Fuerza bruta en el login (dev)

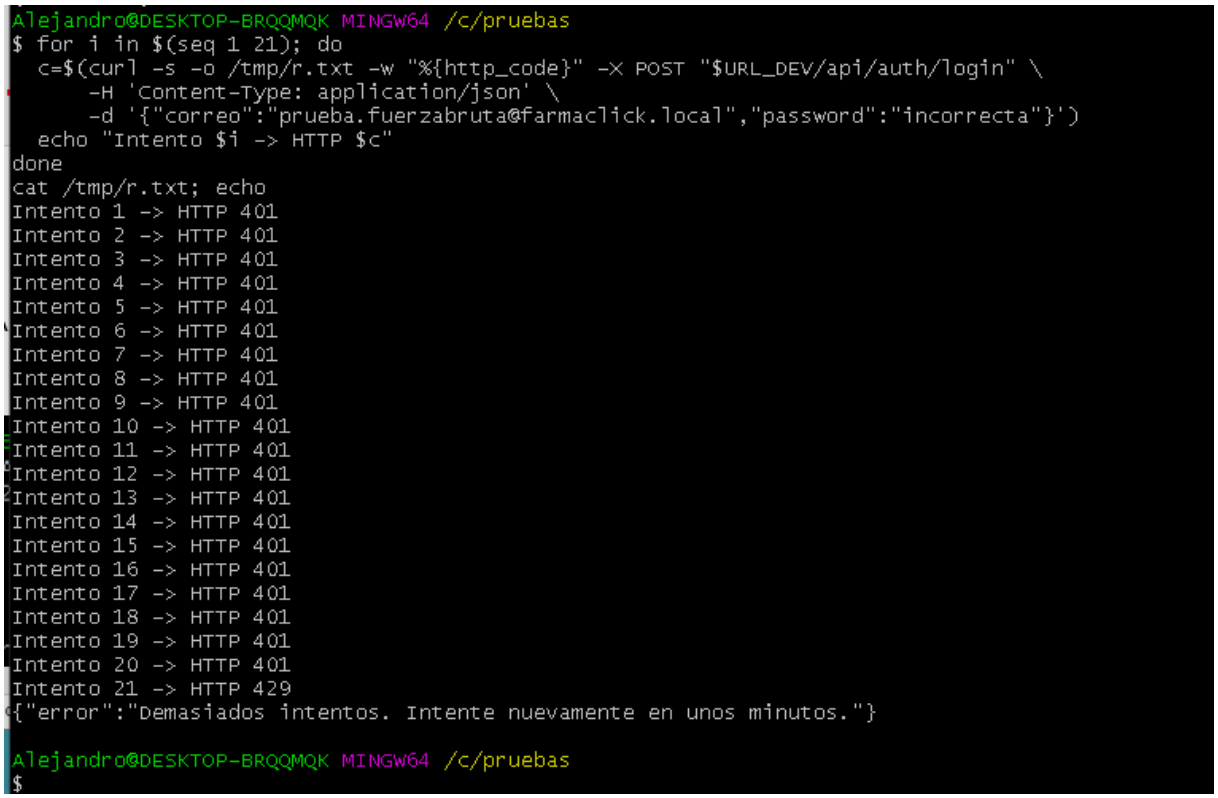


Figura 19 - CP-SEG-10_20261021.png

21 intentos de login con clave incorrecta desde la misma IP: los intentos 1 a 20 responden HTTP 401 y el 21 responde HTTP 429 con "Demasiados intentos. Intente nuevamente en unos minutos." (límite de 20 solicitudes cada 15 minutos por IP).

CP-SEG-11 - Escaneo de vulnerabilidades web con OWASP ZAP (producción)

Escaneo baseline de ZAP 2.17.0 sobre https://farmaclick-medifarm.duckdns.org (21-10-2026 02:17 UTC, es decir, 20-10-2026 23:17 hora de Chile). Resultado: 0 alertas de riesgo alto, 1 medio (Content-Security-Policy no definida), 5 bajo y 5 informativas. El reporte completo está en CP-SEG-11_20261020_reporte.html.

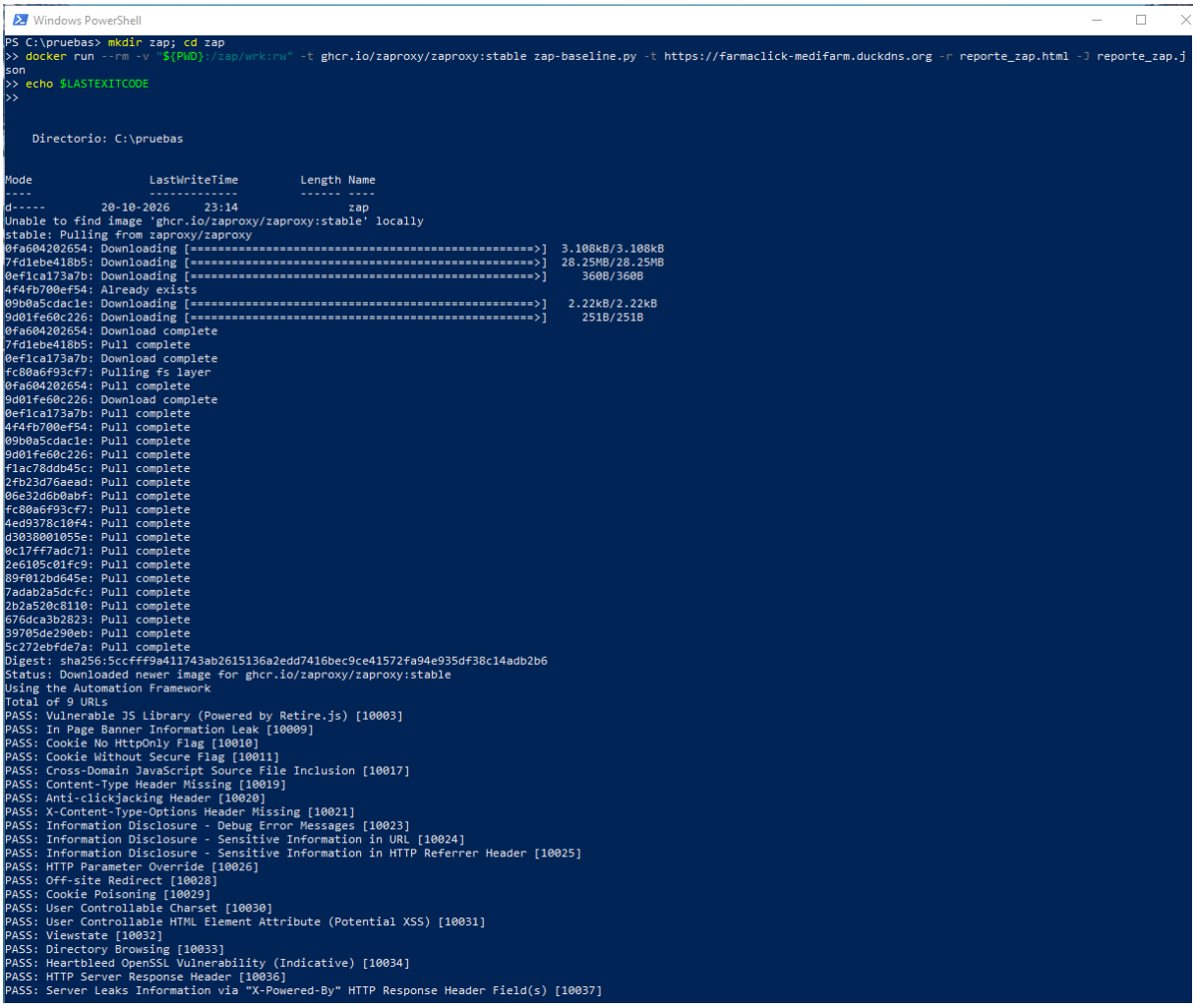


Figura 20 - CP-SEG-11_20261020_1.png

Ejecución de ZAP en contenedor (ghcr.io/zaproxy/zaproxy:stable) y comienzo de la lista de reglas aprobadas (PASS).

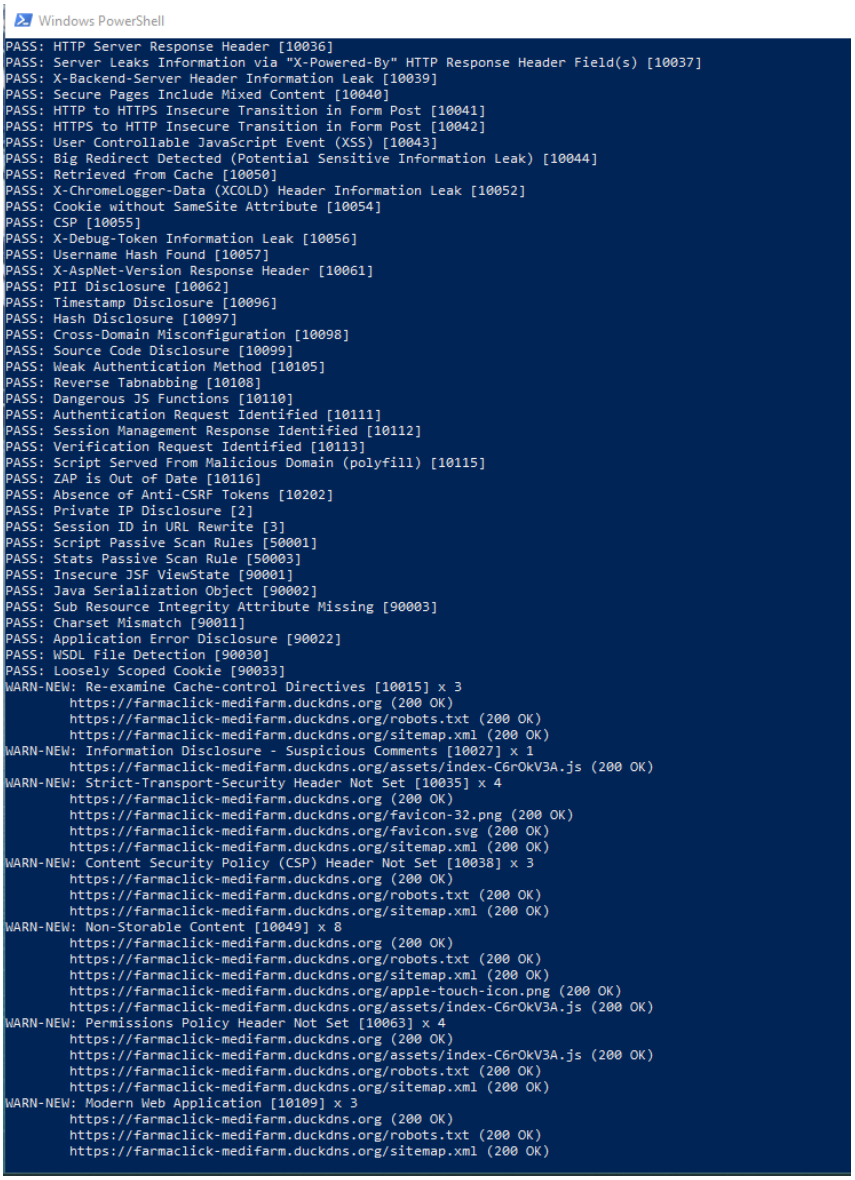


Figura 21 - CP-SEG-11_20261020_2.png

Continuación de la salida: reglas aprobadas y avisos (WARN-NEW) del escaneo pasivo.

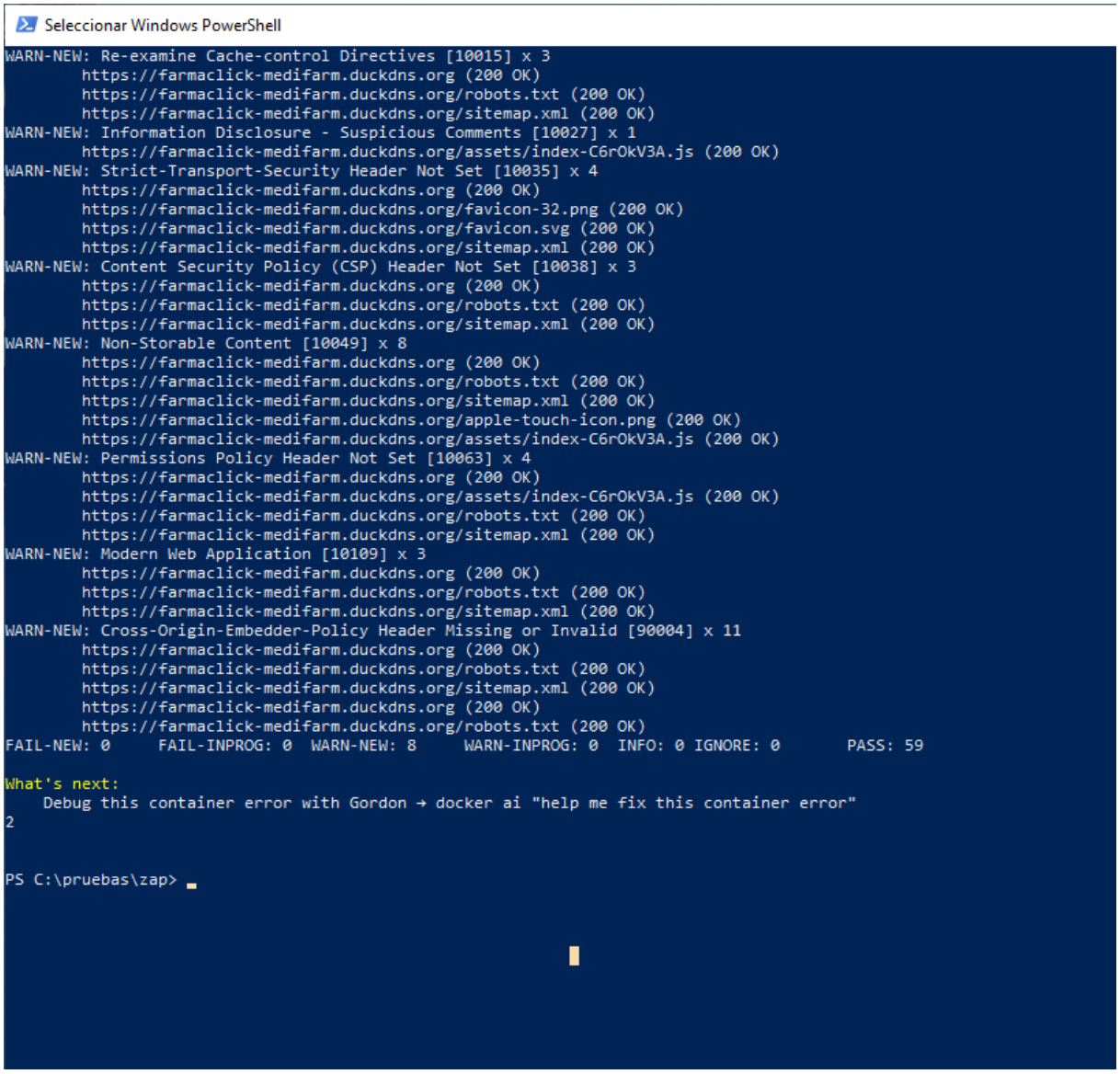


Figura 22 - CP-SEG-11_20261020_3.png

Final de la salida y totales: FAIL-NEW 0, WARN-NEW 8, PASS 59.

CP-SEG-12 - Dependencias vulnerables (npm audit)

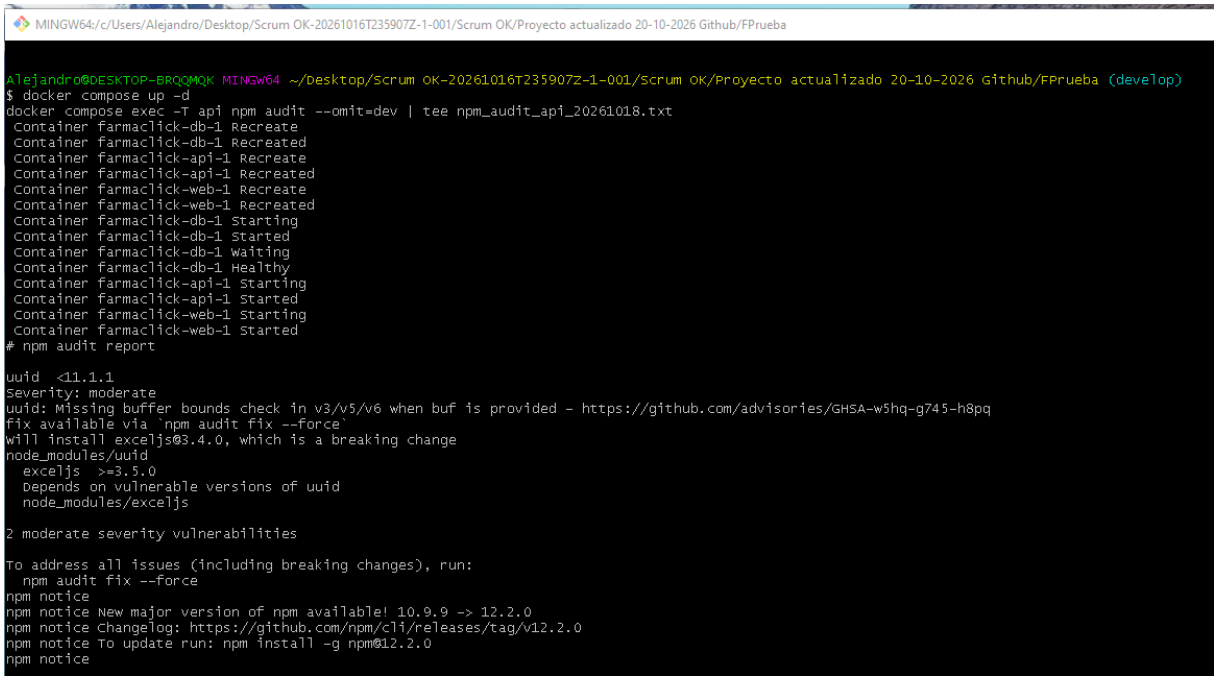


Figura 23 - CP-SEG-12_20261020.png

npm audit --omit=dev del backend: 2 vulnerabilidades moderadas (uuid < 11.1.1, GHSA-w5hq-g745-h8pq, a través de exceljs) y ninguna crítica ni alta; la corrección automática exige un cambio incompatible (exceljs 3.4.0). En la captura el archivo de salida figura como npm_audit_api_20261018.txt; se conserva como npm_audit_api_20261020.txt, que es la fecha real de la ejecución.

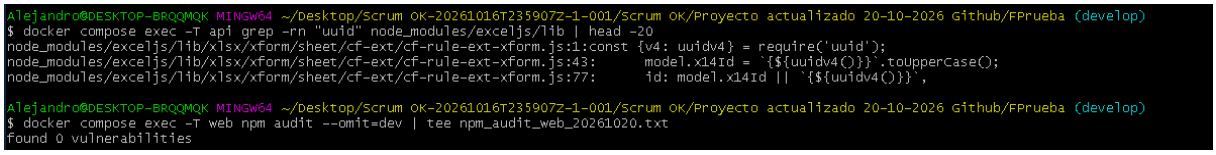


Figura 24 - CP-SEG-12_20261020_2.png

Verificación de la observación: exceljs solo usa uuid v4 sin el parámetro buf (el aviso afecta a v3, v5 y v6 con buf). Debajo, npm audit --omit=dev del frontend: found 0 vulnerabilities.

CP-SEG-13 - RLS y privilegios de la base: Supabase dev

Consultas de seguridad_rls.sql en el SQL Editor de Supabase (dev). Esperado: 0 tablas sin RLS, 0 privilegios para anon y authenticated, 39 tablas con política y 3 tareas programadas activas.

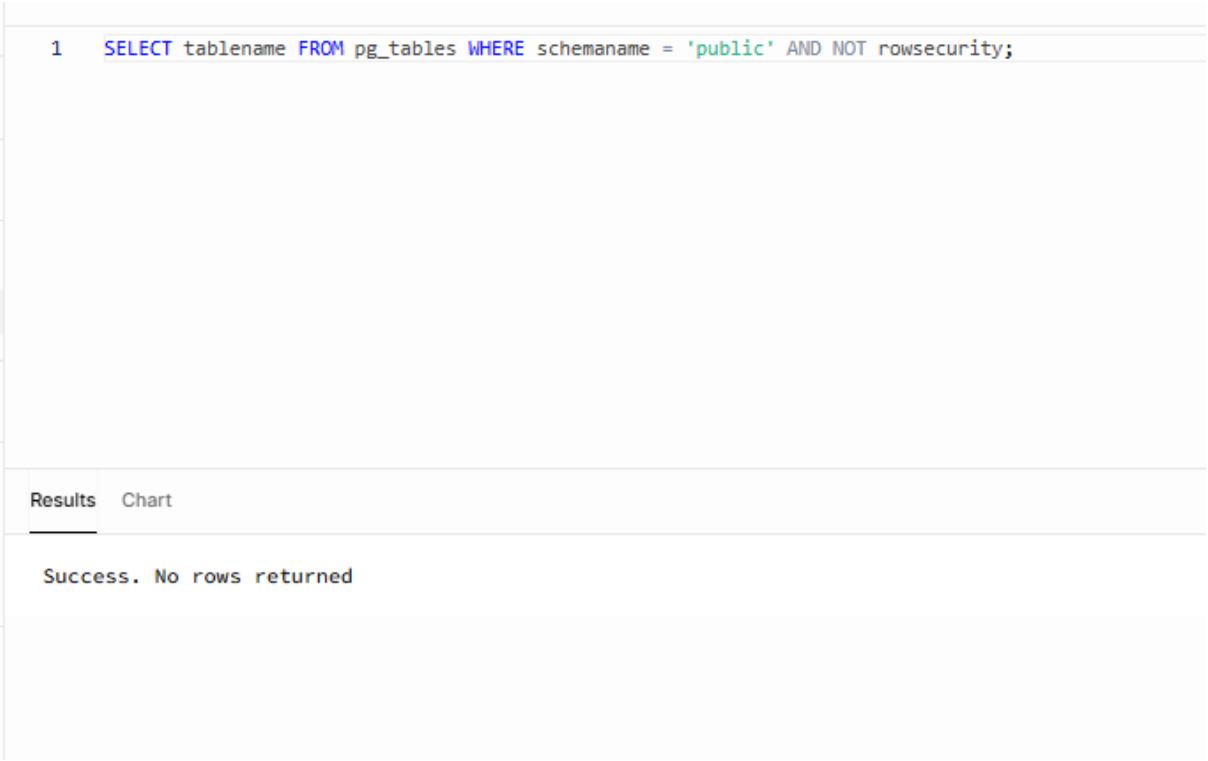


Figura 25 - CP-SEG-13_20261020_dev_1.png
Tablas del esquema public sin RLS: "Success. No rows returned" (0).

```sql
SELECT grantee, table_name, privilege_type FROM information_schema.role_table_grants
WHERE table_schema = 'public' AND grantee IN ('anon', 'authenticated');
```

Results Chart

Success. No rows returned

Figura 26 - CP-SEG-13_20261020_dev_2.png
Privilegios de anon y authenticated sobre las tablas de public: "Success. No rows returned" (0).

```sql
SELECT count(DISTINCT tablename) FROM pg_policies WHERE schemaname = 'public' AND policyname = 'p_backend_all';
```

Results Chart

count
39

Figura 27 - CP-SEG-13_20261020_dev_3.png
Tablas con la política p_backend_all: count = 39.

```
1   SELECT jobname, schedule, active FROM cron.job ORDER BY jobname;
```

Results Chart

jobname	schedule	active
farmaclick-baja-vencidos	0 5 * * *	true
farmaclick-cierre-automatico	59 * * * *	true
farmaclick-liberar-reservas	*/5 * * * *	true

Figura 28 - CP-SEG-13_20261020_dev_5.png

Tareas programadas (cron.job): farmaclick-baja-vencidos (0 5 * * *), farmaclick-cierre-automatico (59 * * * *) y farmaclick-liberar-reservas (*/5 * * * *), las tres activas.

CP-SEG-13 - RLS y privilegios de la base: Supabase producción

Mismas consultas en el proyecto farmaclick-prod (el editor muestra la etiqueta PRODUCTION).

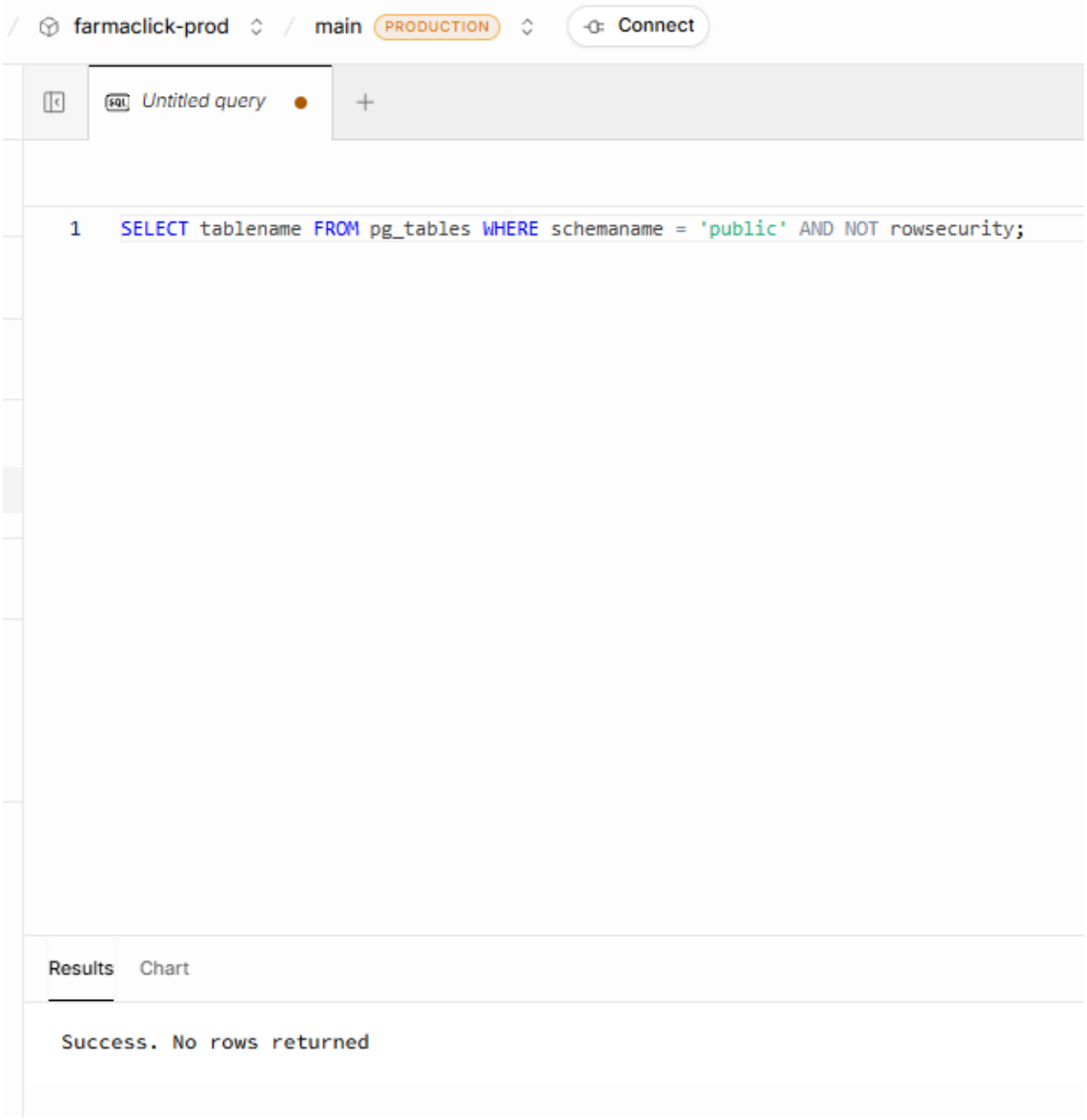


Figura 29 - CP-SEG-13_20261020_prod_1.png

Tablas del esquema public sin RLS: "Success. No rows returned" (0).

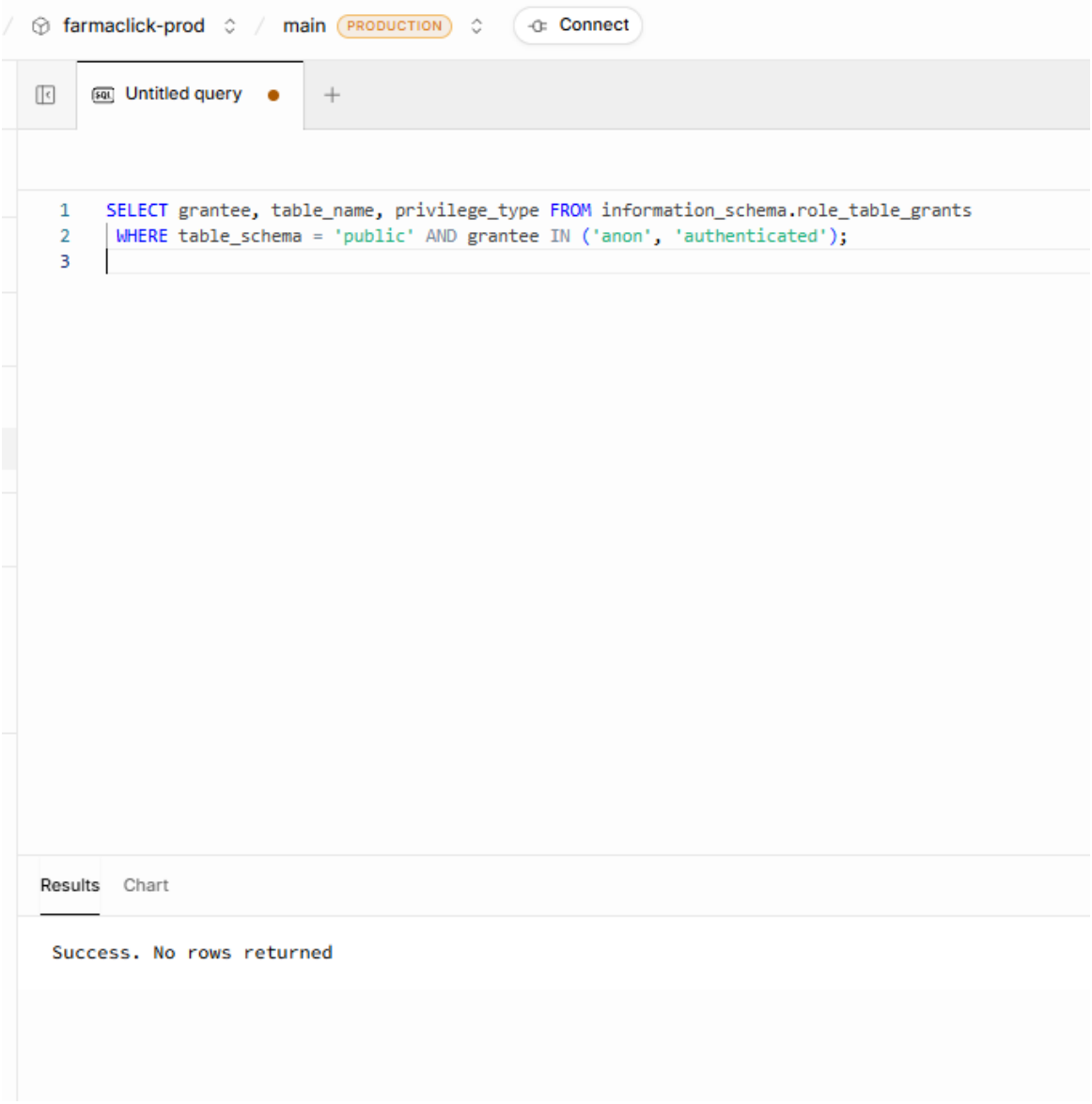


Figura 30 - CP-SEG-13_20261020_prod_2.png
Privilegios de anon y authenticated sobre las tablas de public: "Success. No rows returned" (0).

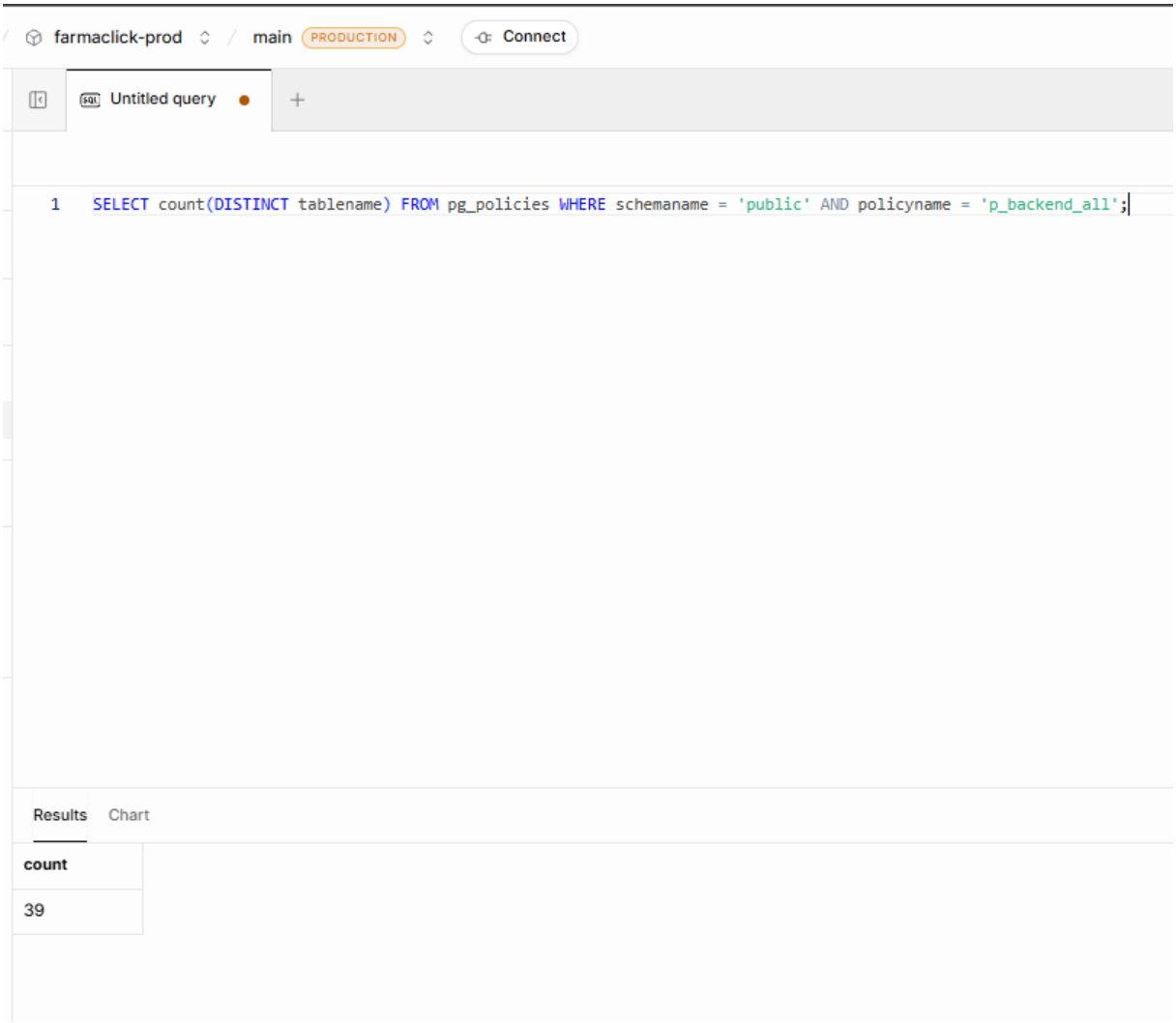


Figura 31 - CP-SEG-13_20261020_prod_3.png
Tablas con la política p_backend_all: count = 39.



Figura 32 - CP-SEG-13_20261020_prod_5.png

Tareas programadas (cron.job): las tres tareas de FarmaClick activas.

CP-SEG-14 - Secretos en el repositorio: prueba negativa

La ejecución con el repositorio limpio está en la Figura 7 (CP-SEG-14_20261020_1.png). Para la prueba negativa se sube a una rama de prueba un archivo credencial_prueba.txt con un valor de relleno y se abre un Pull Request hacia main: el job seguridad debe fallar y detener el pipeline. El Pull Request se cierra sin fusionar y se elimina la rama de prueba local.

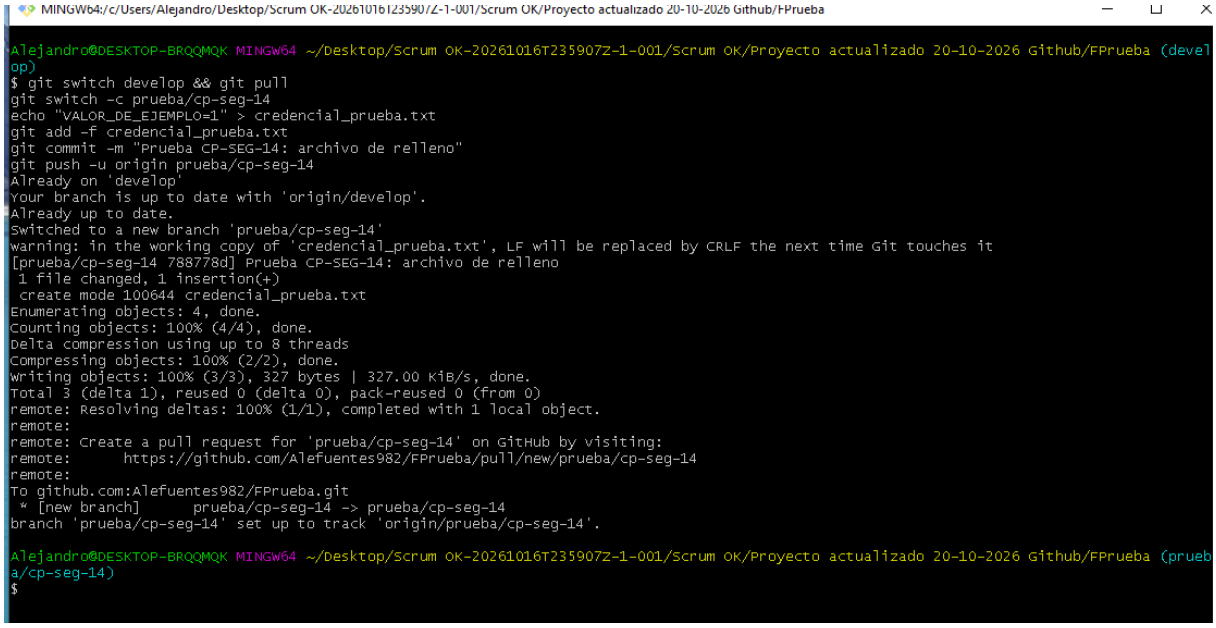


Figura 33 - CP-SEG-14_20261021_2a_push_rama_prueba.png

Creación de la rama prueba/cp-seg-14, del archivo credencial_prueba.txt (valor de relleno) y push a GitHub.

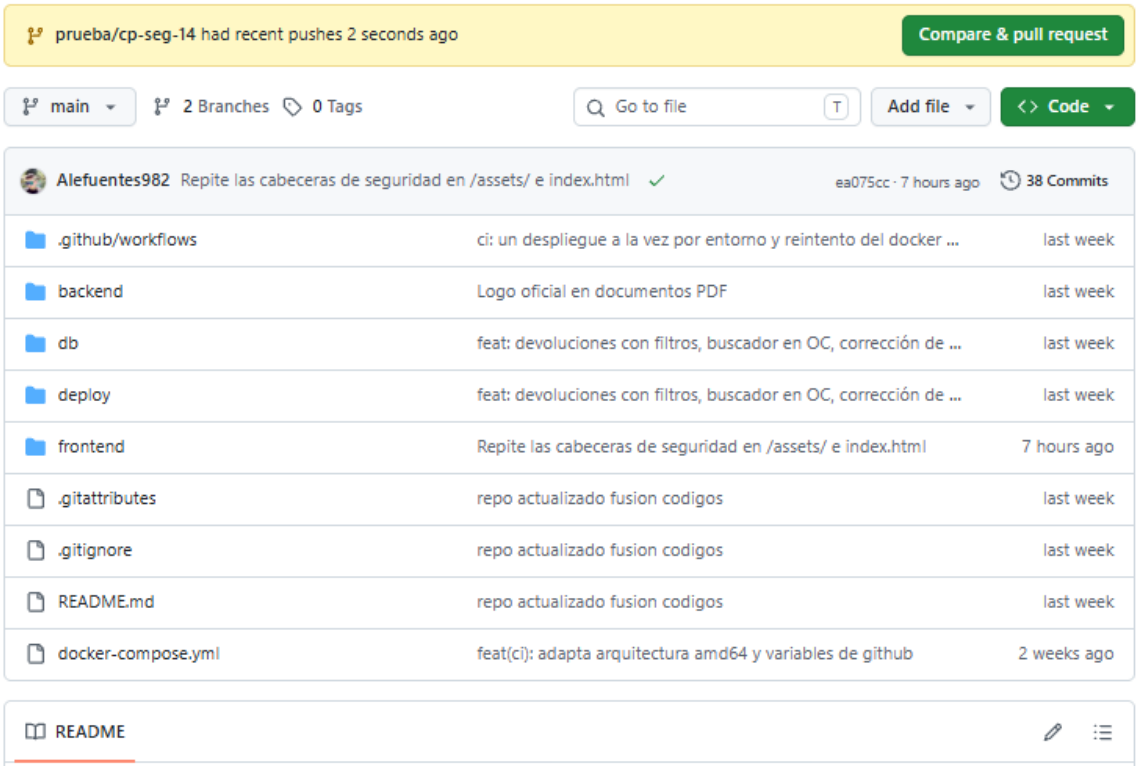


Figura 34 - `CP-SEG-14_20261021_2b_rama_publicada.png`
GitHub detecta la rama: "prueba/cp-seg-14 had recent pushes".

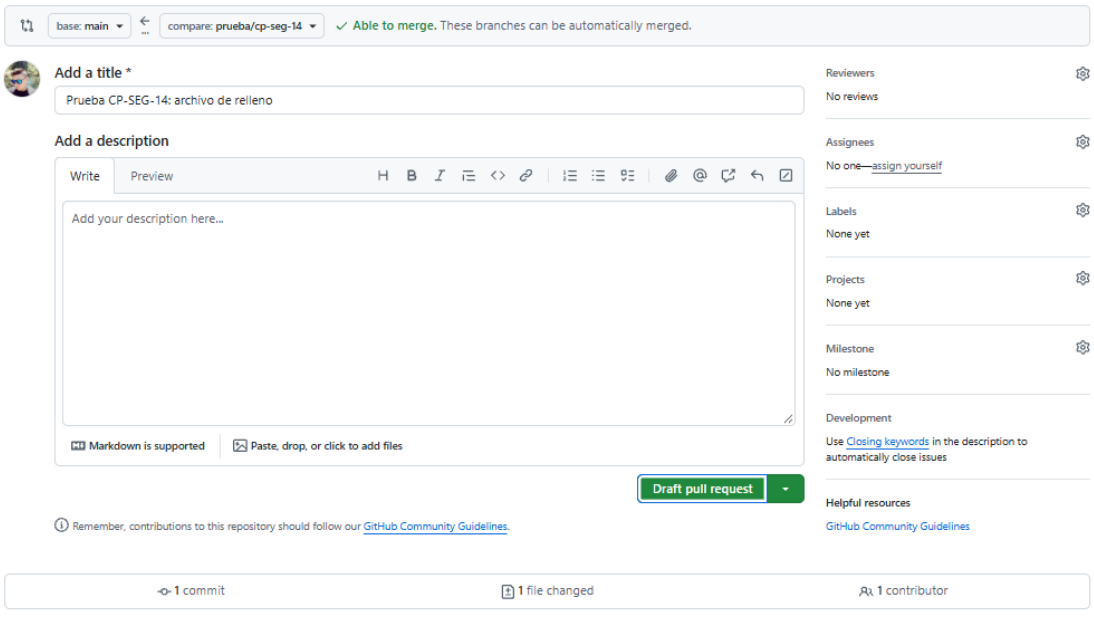


Figura 35 - `CP-SEG-14_20261021_2c_pull_request.png`
Formulario del Pull Request "Prueba CP-SEG-14: archivo de relleno" (base main).

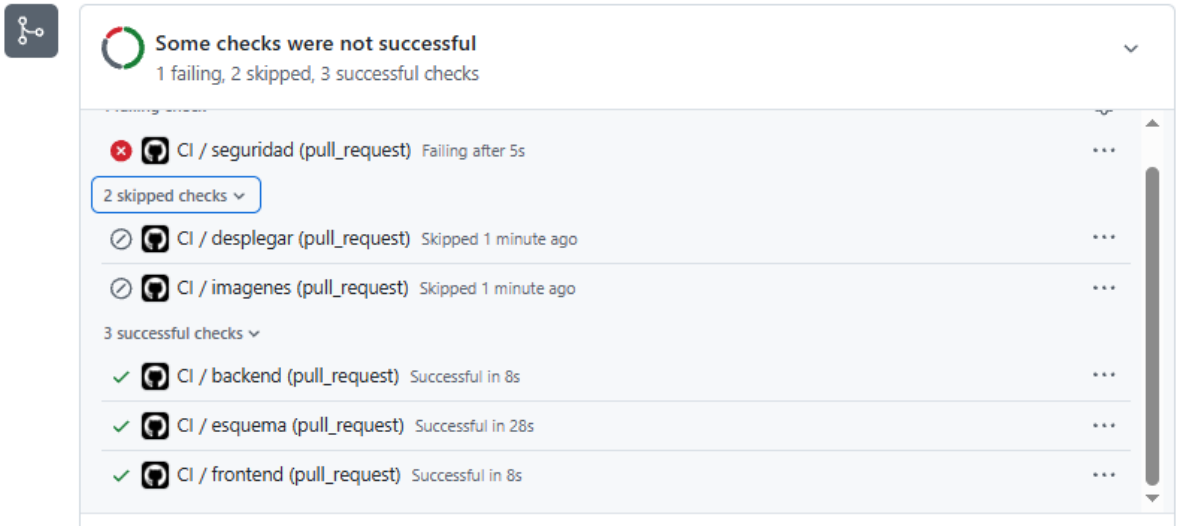


Figura 36 - `CP-SEG-14_20261021_2d_checks.png`
Resultado de las verificaciones del Pull Request: seguridad falla (5 s); desplegar e imágenes quedan omitidos; backend, esquema y frontend pasan.

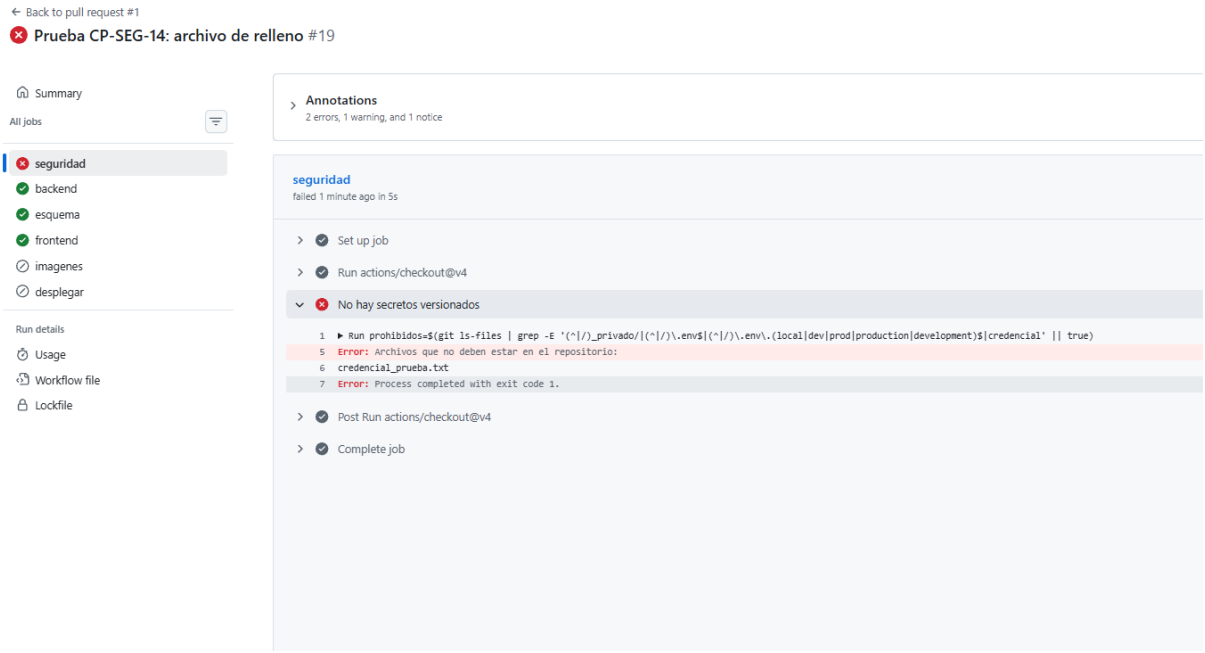


Figura 37 - `CP-SEG-14_20261021_2e_job_seguridad_fallido.png`
Ejecución n.º 19, job seguridad: el paso "No hay secretos versionados" falla con "Error: Archivos que no deben estar en el repositorio: credencial_prueba.txt".



Figura 38 - `CP-SEG-14_20261021_2f_pull_request_cerrado.png`
El Pull Request #1 queda en estado Closed, cerrado sin fusionar.

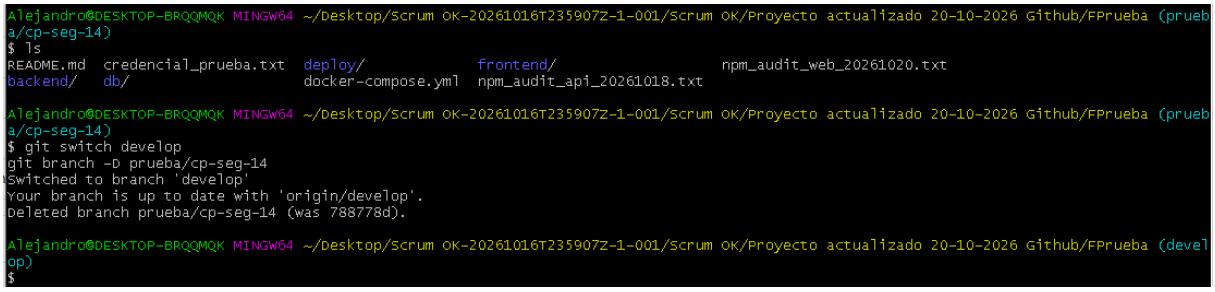


Figura 39 - CP-SEG-14_20261021_2g_limpieza.png

Limpieza: se vuelve a la rama develop y se elimina localmente la rama de prueba.

CP-SEG-15 - HTTPS y certificado (producción)

Certificado emitido por Let's Encrypt para farmaclick-medifarm.duckdns.org, válido hasta el 11-01-2027. Calificación de SSL Labs: A-.

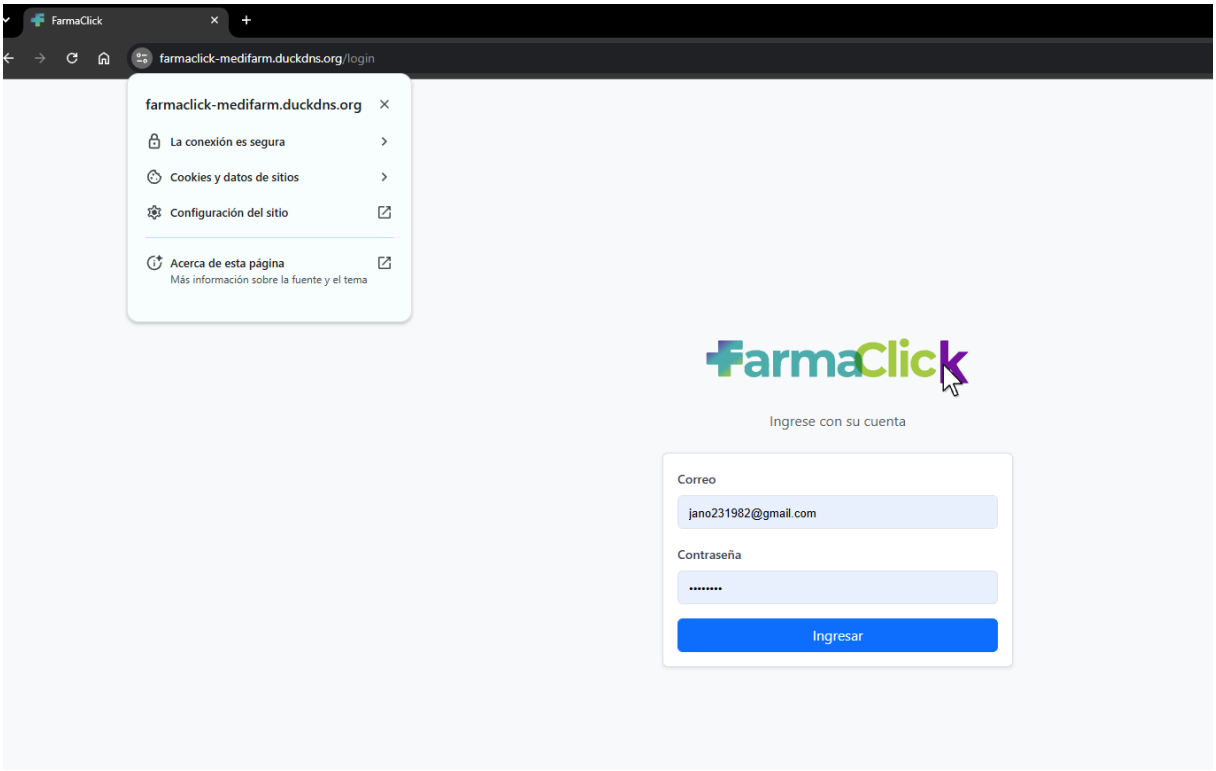


Figura 40 - CP-SEG-15_20261020_1a_navegador_candado.png

Pantalla de login en https://farmaclick-medifarm.duckdns.org y panel del candado: "La conexión es segura".

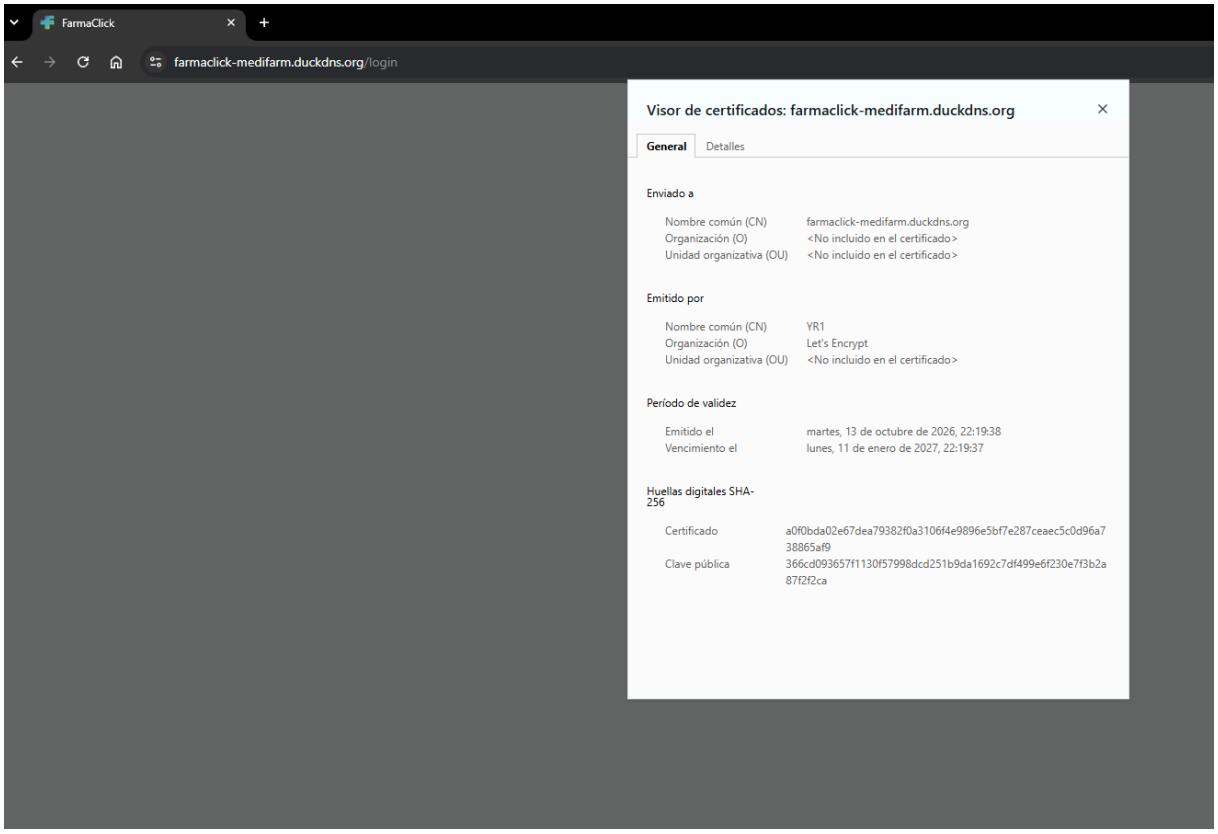


Figura 41 - `CP-SEG-15_20261020_1b_navegador_certificado.png`

Visor de certificados, pestaña General: emitido para farmaclick-medifarm.duckdns.org por YR1 (Let's Encrypt); emitido el 13-10-2026 y vence el 11-01-2027.

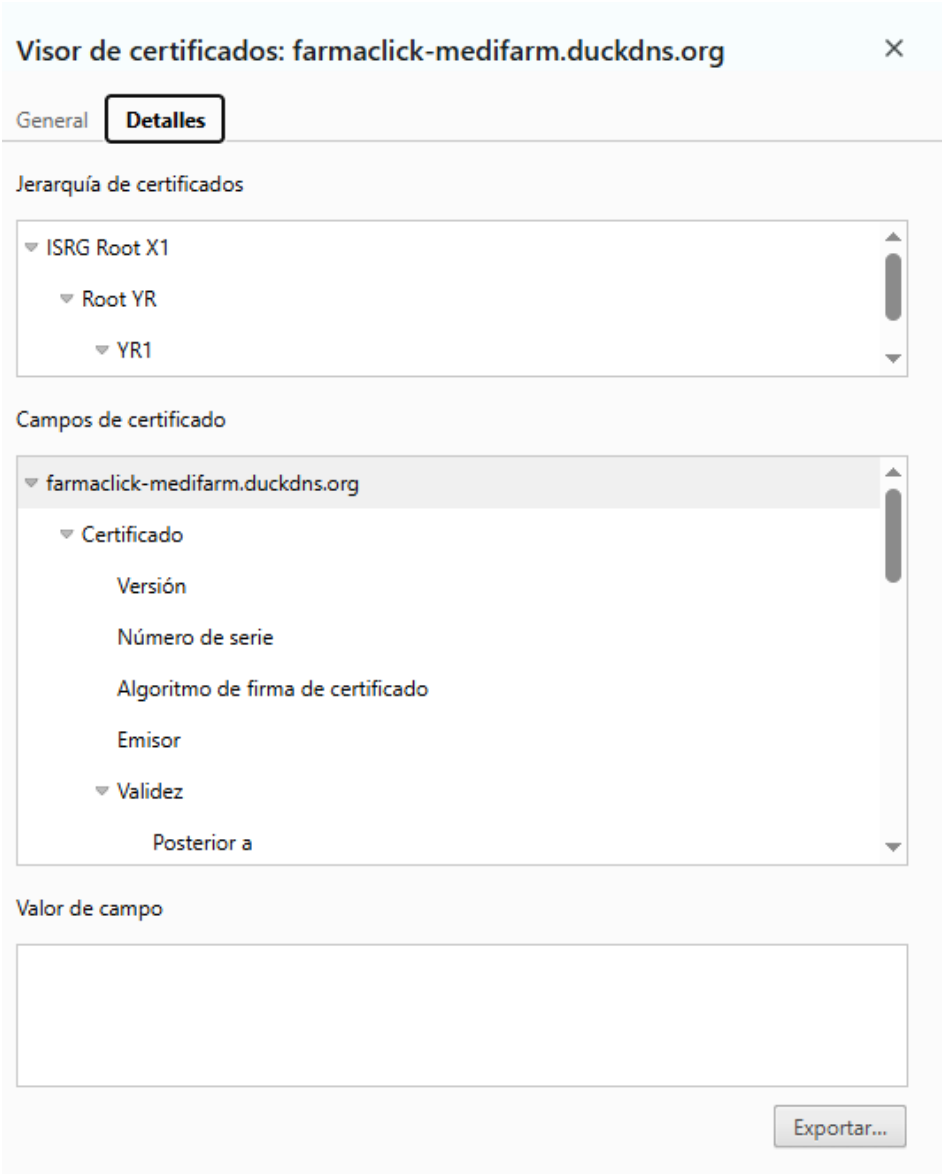


Figura 42 - `CP-SEG-15_20261020_1c_navegador_certificado_detalles.png`
Visor de certificados, pestaña Detalles: jerarquía ISRG Root X1, Root YR, YR1.

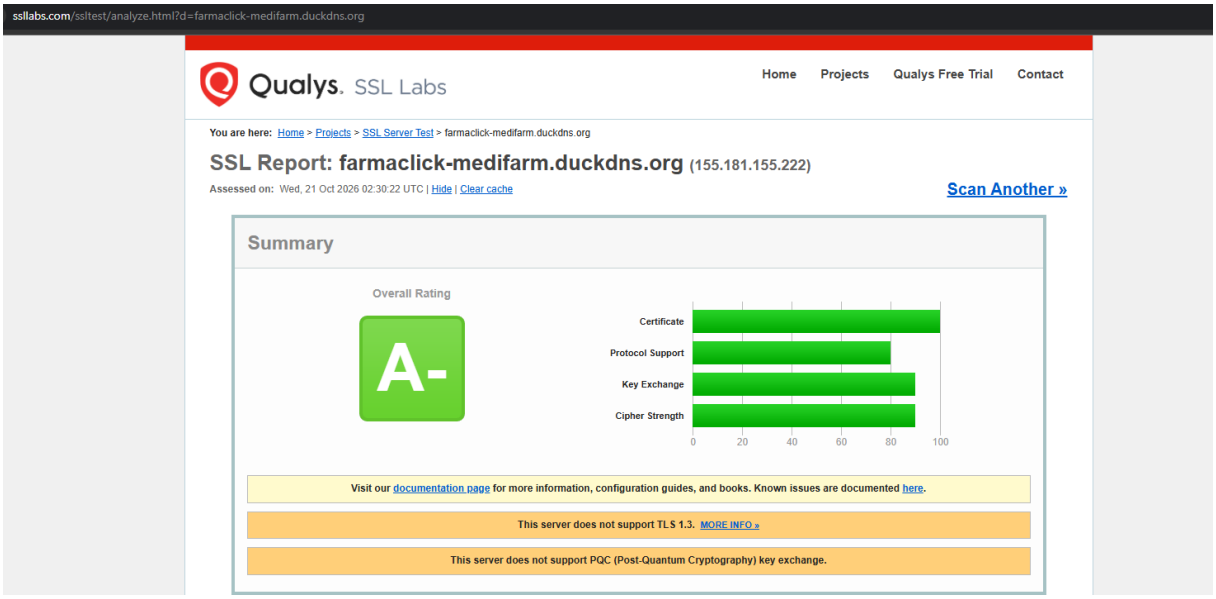


Figura 43 - CP-SEG-15_20261020_2a_ssllabs_resumen.png

SSL Labs (21-10-2026 02:30 UTC): calificación general A-. Avisos: el servidor no admite TLS 1.3 ni intercambio de claves poscuántico.

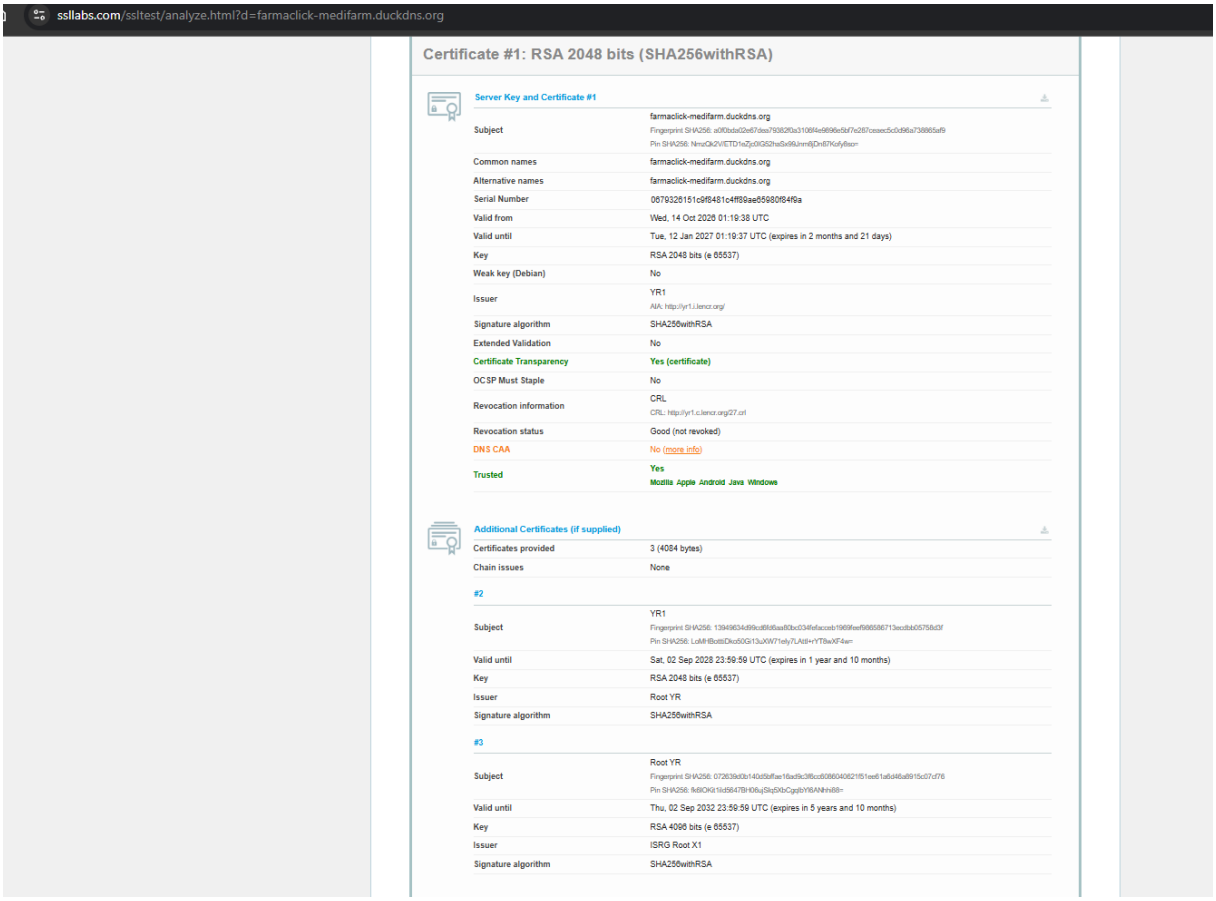


Figura 44 - CP-SEG-15_20261020_2b_ssllabs_certificado.png

SSL Labs: certificado n.º 1, RSA 2048 bits (SHA256withRSA), válido hasta el 12-01-2027 (UTC), con transparencia de certificados y confiable en Mozilla, Apple, Android, Java y Windows.

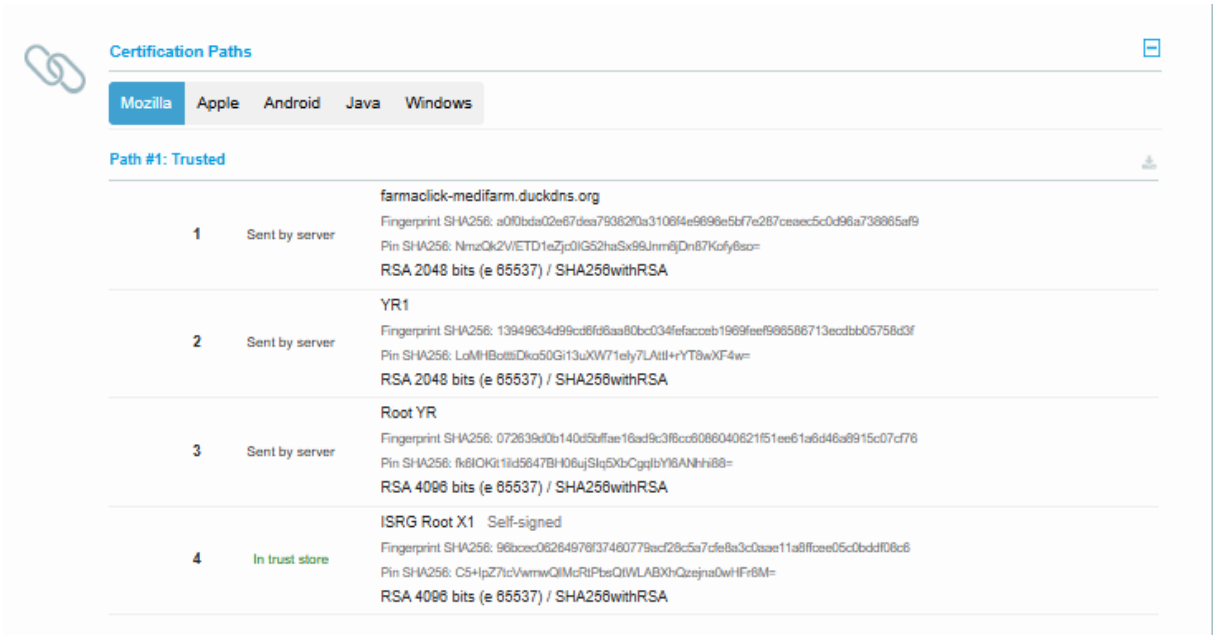


Figura 45 - CP-SEG-15_20261020_2c_ssllabs_rutas_mozilla.png

SSL Labs, rutas de certificación en Mozilla: Path #1 Trusted.

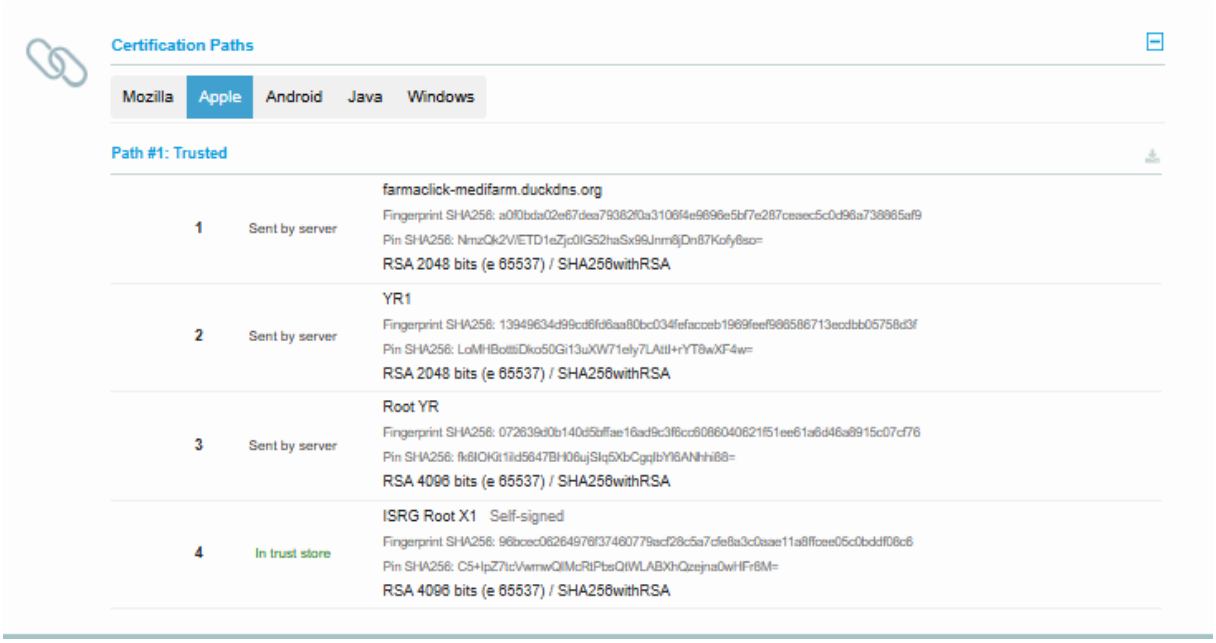


Figura 46 - CP-SEG-15_20261020_2d_ssllabs_rutas_apple.png

SSL Labs, rutas de certificación en Apple: Path #1 Trusted.

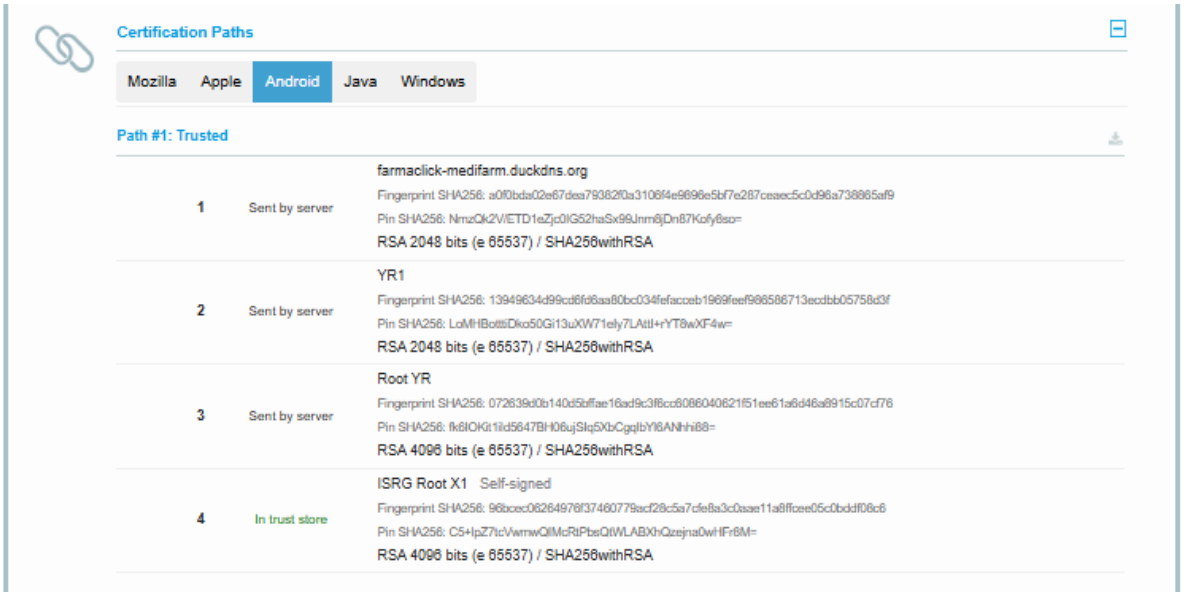


Figura 47 - `CP-SEG-15_20261020_2e_ssllabs_rutas_android.png`

SSL Labs, rutas de certificación en Android: Path #1 Trusted.

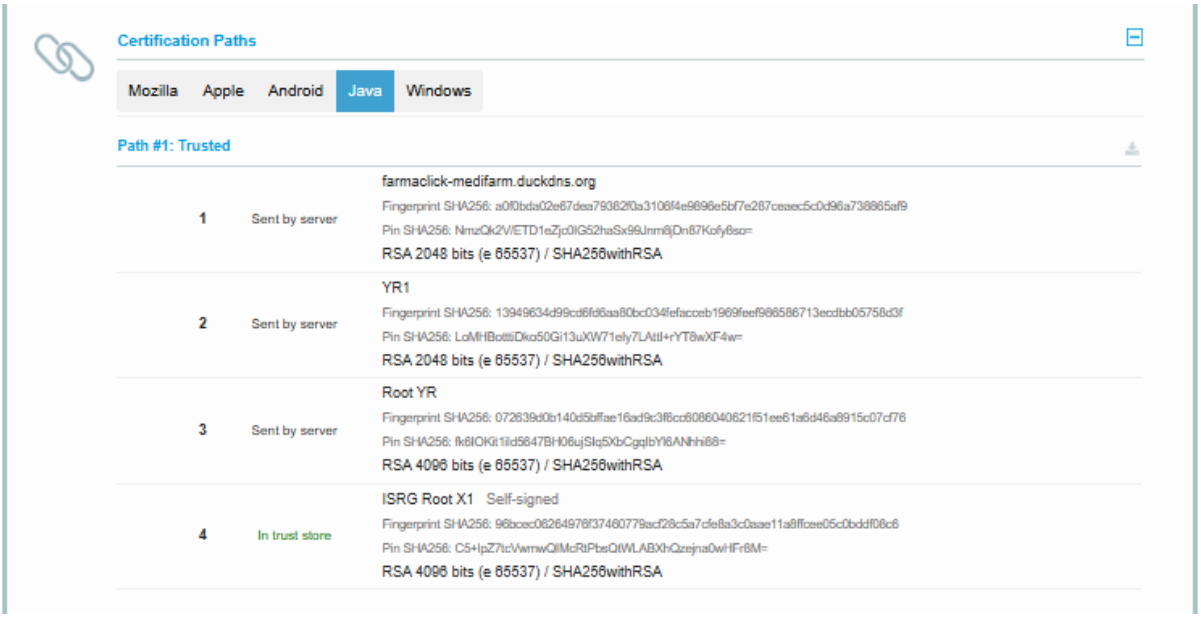


Figura 48 - `CP-SEG-15_20261020_2f_ssllabs_rutas_java.png`

SSL Labs, rutas de certificación en Java: Path #1 Trusted.

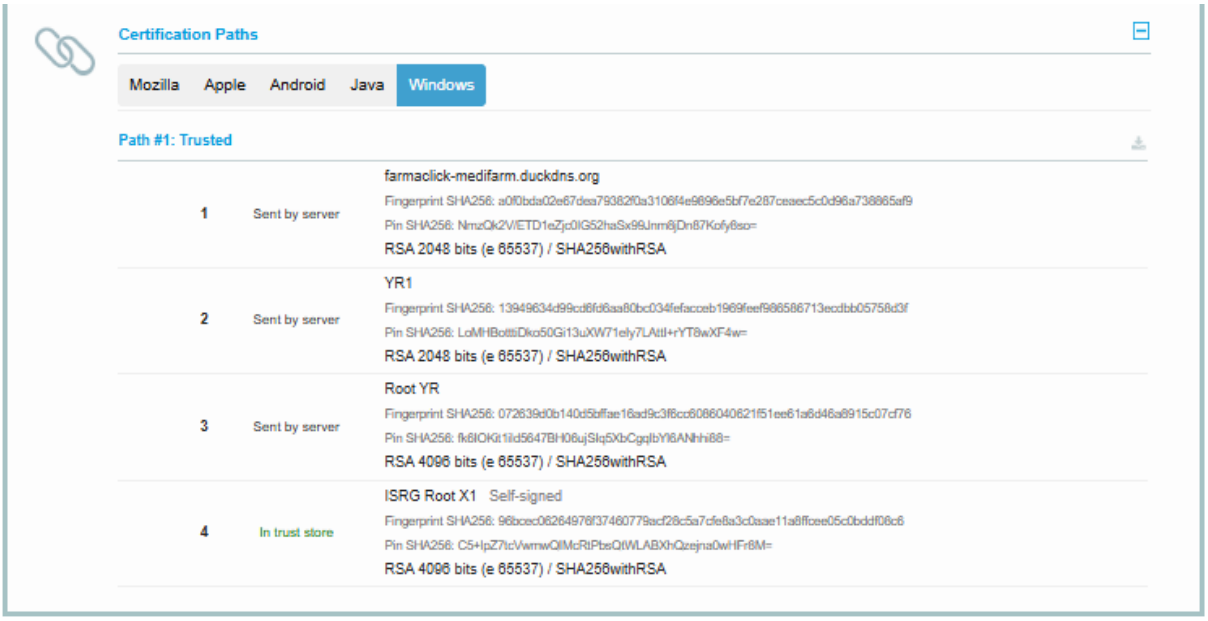
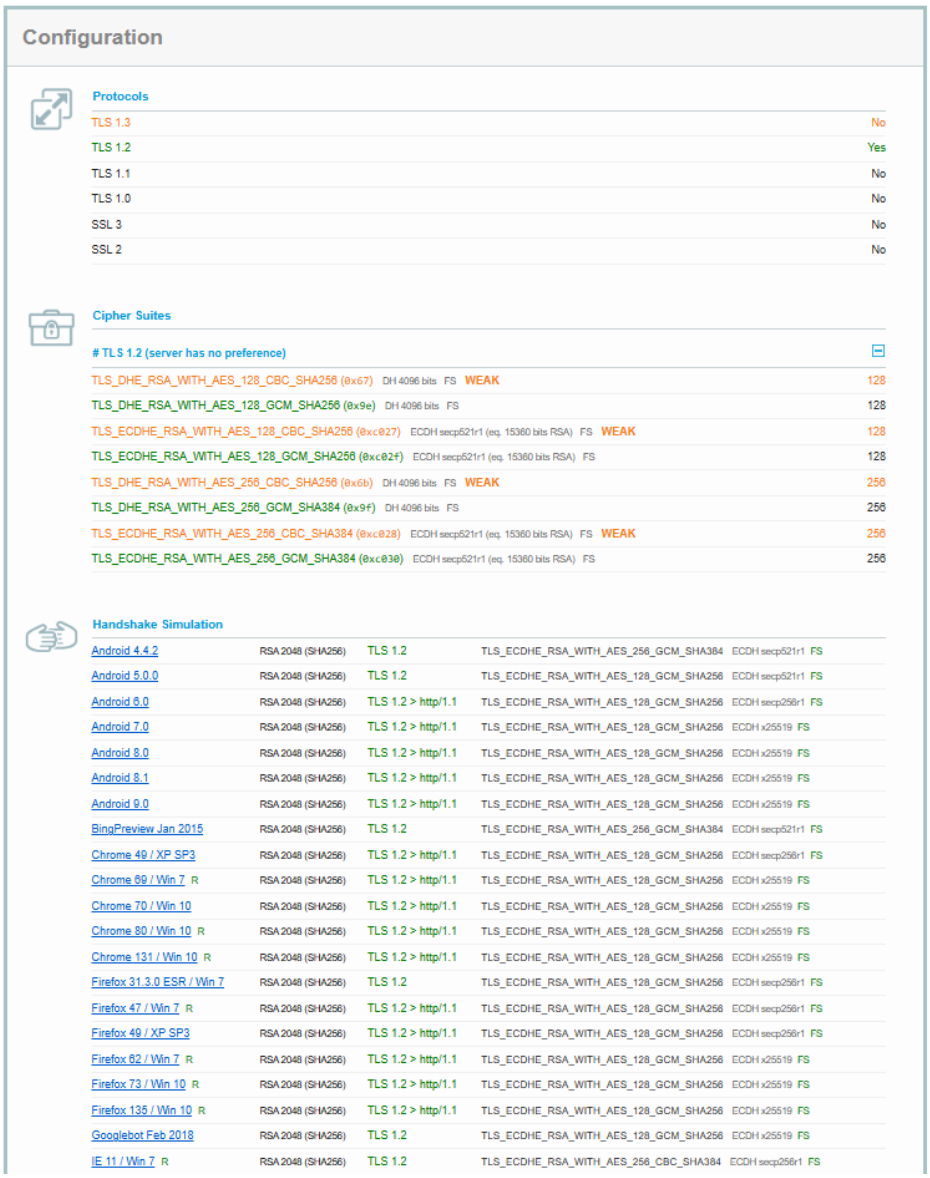


Figura 49 - `CP-SEG-15_20261020_2g_ssllabs_rutas_windows.png`

SSL Labs, rutas de certificación en Windows: Path #1 Trusted.



Configuration

Protocols

TLS 1.3	No
TLS 1.2	Yes
TLS 1.1	No
TLS 1.0	No
SSL 3	No
SSL 2	No

Cipher Suites

TLS 1.2 (server has no preference)

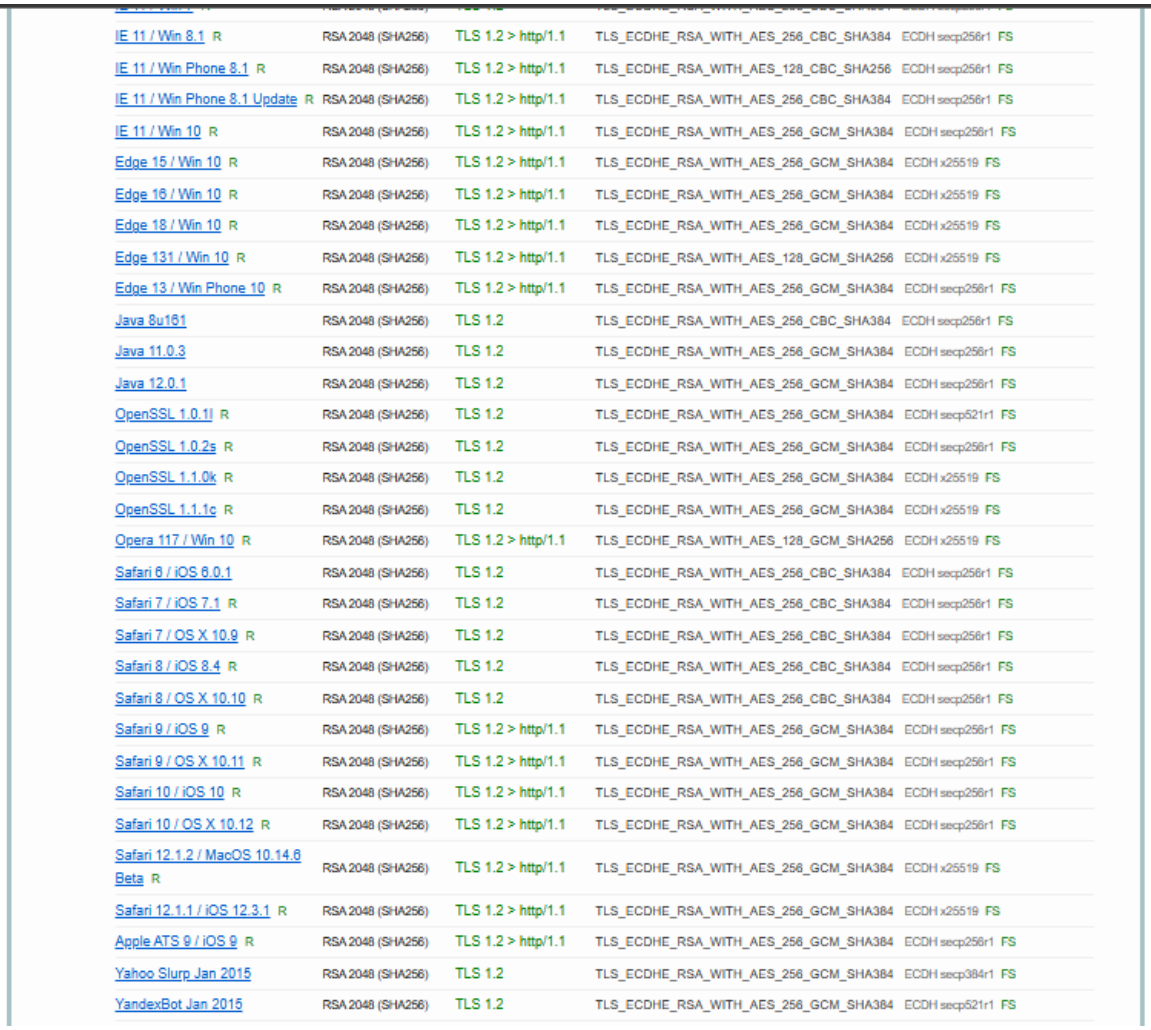
TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 4096 bits FS WEAK	128
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 4096 bits FS	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp521r1 (eq. 15360 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp521r1 (eq. 15360 bits RSA) FS	128
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (0x6b)	DH 4096 bits FS WEAK	256
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 4096 bits FS	256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp521r1 (eq. 15360 bits RSA) FS WEAK	256
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp521r1 (eq. 15360 bits RSA) FS	256

Handshake Simulation

Android 4.4.2	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384	ECDH secp521r1 FS
Android 5.0.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp521r1 FS
Android 6.0	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1 FS
Android 7.0	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Android 8.0	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Android 8.1	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Android 9.0	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
BingPreview Jan 2015	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384	ECDH secp521r1 FS
Chrome 49 / XP SP3	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1 FS
Chrome 69 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Chrome 70 / Win 10	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Chrome 80 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Chrome 131 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Firefox 31.3.0 ESR / Win 7	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1 FS
Firefox 47 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1 FS
Firefox 49 / XP SP3	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1 FS
Firefox 62 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Firefox 73 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Firefox 135 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
Googlebot Feb 2018	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH x25519 FS
IE 11 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384	ECDH secp256r1 FS

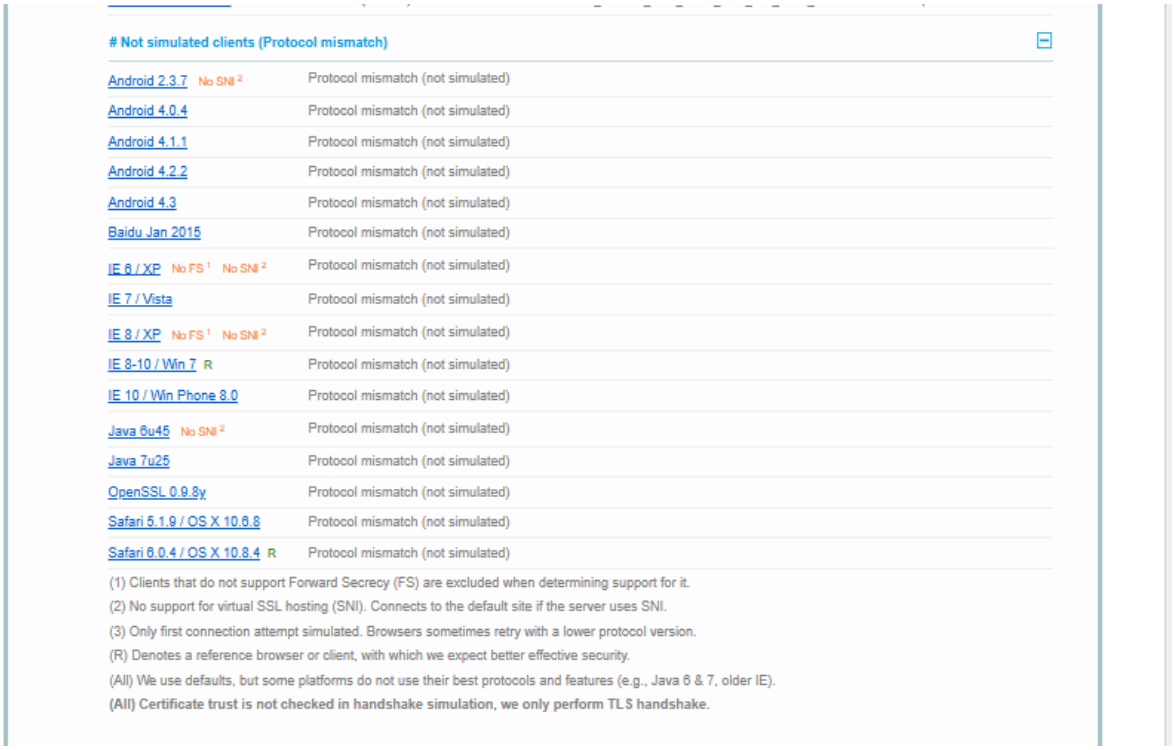
Figura 50 - CP-SEG-15_20261020_2h_ssllabs_configuracion.png

SSL Labs, configuración: solo TLS 1.2 habilitado, suites de cifrado y comienzo de la simulación de clientes.



IE 11 / Win 8.1 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
IE 11 / Win Phone 8.1 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 ECDH secp256r1 FS
IE 11 / Win Phone 8.1 Update R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
IE 11 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Edge 15 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Edge 16 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Edge 18 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Edge 131 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH x25519 FS
Edge 13 / Win Phone 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Java 8u161	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Java 11.0.3	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Java 12.0.1	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
OpenSSL 1.0.1l R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS
OpenSSL 1.0.2s R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
OpenSSL 1.1.0k R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
OpenSSL 1.1.1c R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Opera 117 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH x25519 FS
Safari 6 / iOS 6.0.1	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Safari 7 / iOS 7.1 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Safari 7 / OS X 10.9 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Safari 8 / iOS 8.4 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Safari 8 / OS X 10.10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp256r1 FS
Safari 9 / iOS 9 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Safari 9 / OS X 10.11 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Safari 10 / iOS 10 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Safari 10 / OS X 10.12 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Safari 12.1.2 / MacOS 10.14.6 Beta R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Safari 12.1.1 / iOS 12.3.1 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
Apple ATS 9 / iOS 9 R	RSA 2048 (SHA256)	TLS 1.2 > http/1.1	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
Yahoo Slurp Jan 2015	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp384r1 FS
YandexBot Jan 2015	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS

Figura 51 - CP-SEG-15_20261020_2i_ssllabs_simulacion_clientes.png
SSL Labs: simulación de conexión con navegadores y sistemas actuales (continuación).

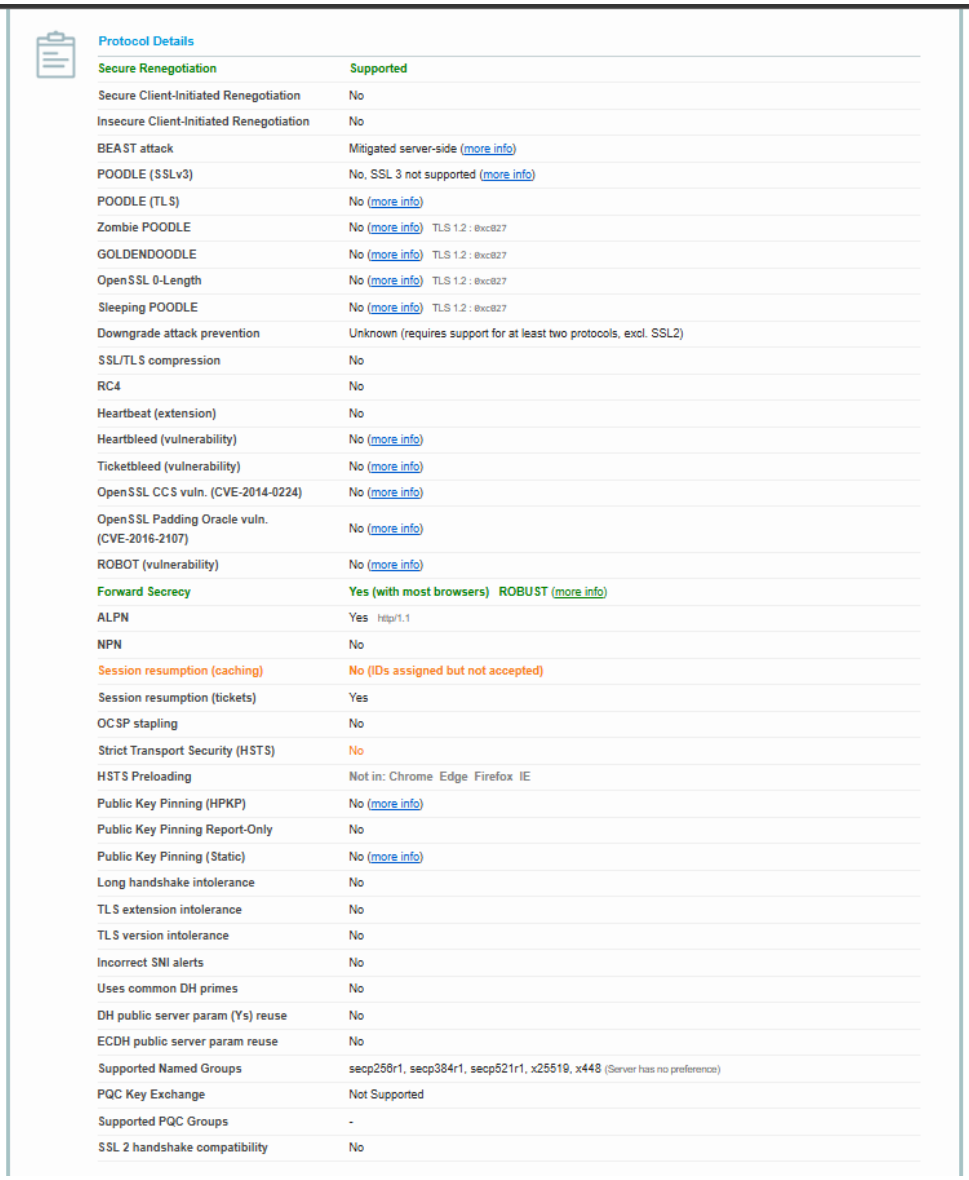


Not simulated clients (Protocol mismatch)

Android 2.3.7 No SNI [2]	Protocol mismatch (not simulated)
Android 4.0.4	Protocol mismatch (not simulated)
Android 4.1.1	Protocol mismatch (not simulated)
Android 4.2.2	Protocol mismatch (not simulated)
Android 4.3	Protocol mismatch (not simulated)
Baidu Jan 2015	Protocol mismatch (not simulated)
IE 6 / XP No FS [1] No SNI [2]	Protocol mismatch (not simulated)
IE 7 / Vista	Protocol mismatch (not simulated)
IE 8 / XP No FS [1] No SNI [2]	Protocol mismatch (not simulated)
IE 8-10 / Win 7 R	Protocol mismatch (not simulated)
IE 10 / Win Phone 8.0	Protocol mismatch (not simulated)
Java 6u45 No SNI [2]	Protocol mismatch (not simulated)
Java 7u25	Protocol mismatch (not simulated)
OpenSSL 0.9.8y	Protocol mismatch (not simulated)
Safari 5.1.9 / OS X 10.6.8	Protocol mismatch (not simulated)
Safari 6.0.4 / OS X 10.8.4 R	Protocol mismatch (not simulated)

(1) Clients that do not support Forward Secrecy (FS) are excluded when determining support for it.
(2) No support for virtual SSL hosting (SNI). Connects to the default site if the server uses SNI.
(3) Only first connection attempt simulated. Browsers sometimes retry with a lower protocol version.
(R) Denotes a reference browser or client, with which we expect better effective security.
(All) We use defaults, but some platforms do not use their best protocols and features (e.g., Java 6 & 7, older IE).
(All) Certificate trust is not checked in handshake simulation, we only perform TLS handshake.

Figura 52 - `CP-SEG-15_20261020_2j_ssllabs_clientes_no_simulados.png`
SSL Labs: clientes antiguos no simulados (protocolo incompatible) y notas.

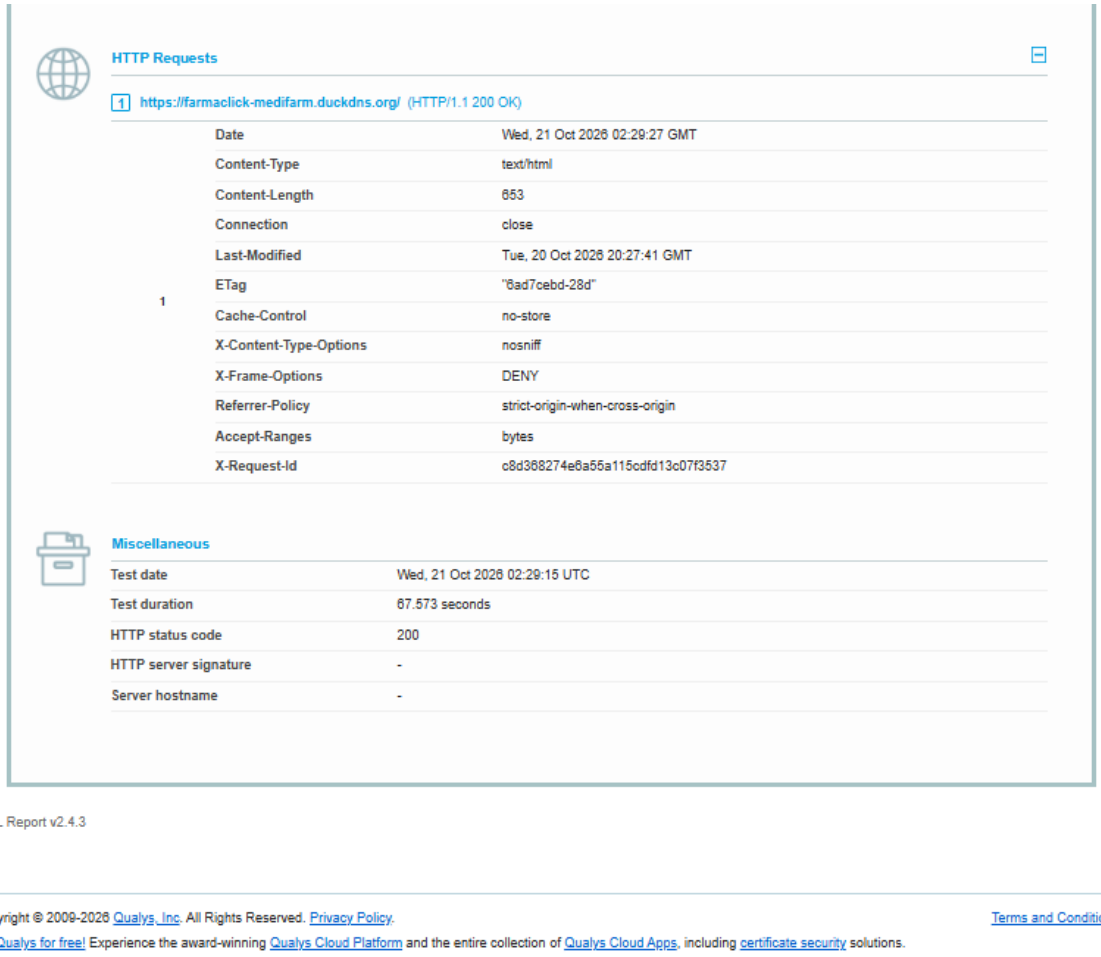


Protocol Details

Secure Renegotiation	**Supported**
Secure Client-Initiated Renegotiation	No
Insecure Client-Initiated Renegotiation	No
BEAST attack	Mitigated server-side (more info)
POODLE (SSLv3)	No, SSL 3 not supported (more info)
POODLE (TLS)	No (more info)
Zombie POODLE	No (more info) TLS 1.2 : 0xc027
GOLDENDOODLE	No (more info) TLS 1.2 : 0xc027
OpenSSL 0-Length	No (more info) TLS 1.2 : 0xc027
Sleeping POODLE	No (more info) TLS 1.2 : 0xc027
Downgrade attack prevention	Unknown (requires support for at least two protocols, excl. SSL2)
SSL/TLS compression	No
RC4	No
Heartbeat (extension)	No
Heartbleed (vulnerability)	No (more info)
Ticketbleed (vulnerability)	No (more info)
OpenSSL CCS vuln. (CVE-2014-0224)	No (more info)
OpenSSL Padding Oracle vuln. (CVE-2016-2107)	No (more info)
ROBOT (vulnerability)	No (more info)
Forward Secrecy	**Yes (with most browsers) ROBUST** (more info)
ALPN	Yes http/1.1
NPN	No
Session resumption (caching)	No (IDs assigned but not accepted)
Session resumption (tickets)	Yes
OCSP stapling	No
Strict Transport Security (HSTS)	No
HSTS Preloading	Not in: Chrome Edge Firefox IE
Public Key Pinning (HPKP)	No (more info)
Public Key Pinning Report-Only	No
Public Key Pinning (Static)	No (more info)
Long handshake intolerance	No
TLS extension intolerance	No
TLS version intolerance	No
Incorrect SNI alerts	No
Uses common DH primes	No
DH public server param (Ys) reuse	No
ECDH public server param reuse	No
Supported Named Groups	secp256r1, secp384r1, secp521r1, x25519, x448 (Server has no preference)
PQC Key Exchange	Not Supported
Supported PQC Groups	-
SSL 2 handshake compatibility	No

Figura 53 - CP-SEG-15_20261020_2k_ssllabs_detalle_protocolo.png

SSL Labs: detalle del protocolo (renegociación segura, Forward Secrecy, HSTS no configurado, grupos admitidos).



HTTP Requests

1 https://farmaclick-medifarm.duckdns.org/ (HTTP/1.1 200 OK)

1	Date	Wed, 21 Oct 2026 02:29:27 GMT
	Content-Type	text/html
	Content-Length	653
	Connection	close
	Last-Modified	Tue, 20 Oct 2026 20:27:41 GMT
	ETag	"6ad7cebd-28d"
	Cache-Control	no-store
	X-Content-Type-Options	nosniff
	X-Frame-Options	DENY
	Referrer-Policy	strict-origin-when-cross-origin
	Accept-Ranges	bytes
	X-Request-Id	c8d368274e6a55a115cdfd13c07f3537

Miscellaneous

Test date	Wed, 21 Oct 2026 02:29:15 UTC
Test duration	67.573 seconds
HTTP status code	200
HTTP server signature	-
Server hostname	-

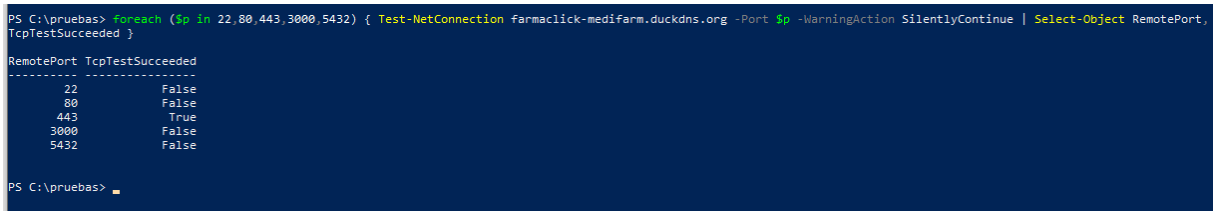
SSL Report v2.4.3

Copyright © 2009-2026 Qualys, Inc. All Rights Reserved. Privacy Policy. Terms and Conditions

Try Qualys for free! Experience the award-winning Qualys Cloud Platform and the entire collection of Qualys Cloud Apps, including certificate security solutions.

Figura 54 - CP-SEG-15_20261020_21_ssllabs_solicitudes_http.png

SSL Labs: solicitud de prueba a https://farmaclick-medifarm.duckdns.org/ (HTTP/1.1 200 OK) con X-Content-Type-Options: nosniff, X-Frame-Options: DENY y Referrer-Policy: strict-origin-when-cross-origin.



```
PS C:\pruebas> foreach ($p in 22,80,443,3000,5432) { Test-NetConnection farmaclick-medifarm.duckdns.org -Port $p -WarningAction SilentlyContinue | Select-Object RemotePort,
TcpTestSucceeded }

RemotePort TcpTestSucceeded
---------- ----------------
        22            False
        80            False
       443             True
      3000            False
      5432            False


PS C:\pruebas>
```

Figura 55 - CP-SEG-15_20261020_3_puertos.png

Prueba de puertos con Test-NetConnection sobre el dominio: solo el 443 responde (True); 22, 80, 3000 y 5432 sin respuesta (False).

CP-SEG-16 - Exposición de la VM de producción

Esperado: la VM no responde directamente desde Internet; el único camino es el balanceador.



Figura 56 - CP-SEG-16_20261020_1.png

curl a la IP pública de la VM de producción por el puerto 80: HTTP 000, "Connection timed out after 10016 milliseconds". En la línea siguiente, el mismo servicio por el dominio responde { "ok": true }.

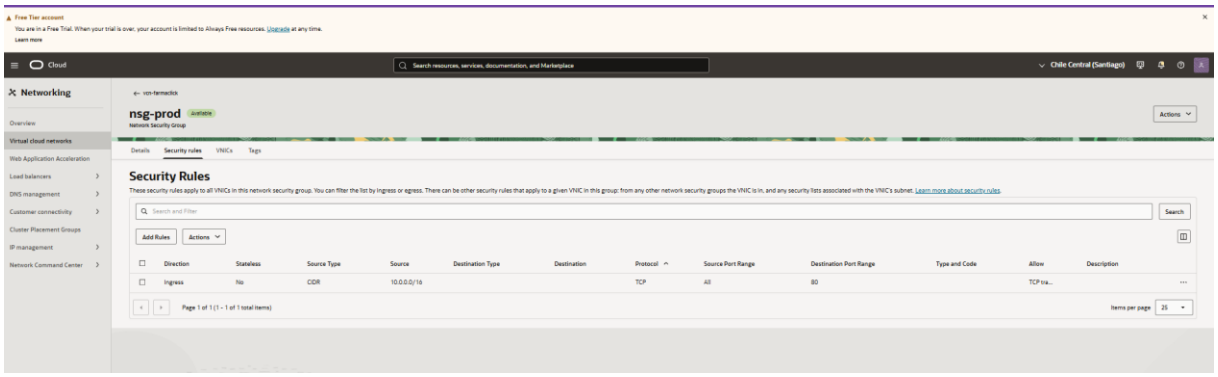


Figura 57 - CP-SEG-16_20261020_2.png

Reglas de seguridad del grupo nsg-prod en Oracle Cloud: una única regla de entrada, TCP al puerto 80, con origen 10.0.0.0/16 (red privada).

6. Observaciones de infraestructura

Estado de las VM observado al conectarse por SSH durante las pruebas (20-10-2026). Las dos VM tienen actualizaciones del sistema operativo pendientes y un reinicio pendiente; queda registrado como observación en el plan de pruebas (sección 7).

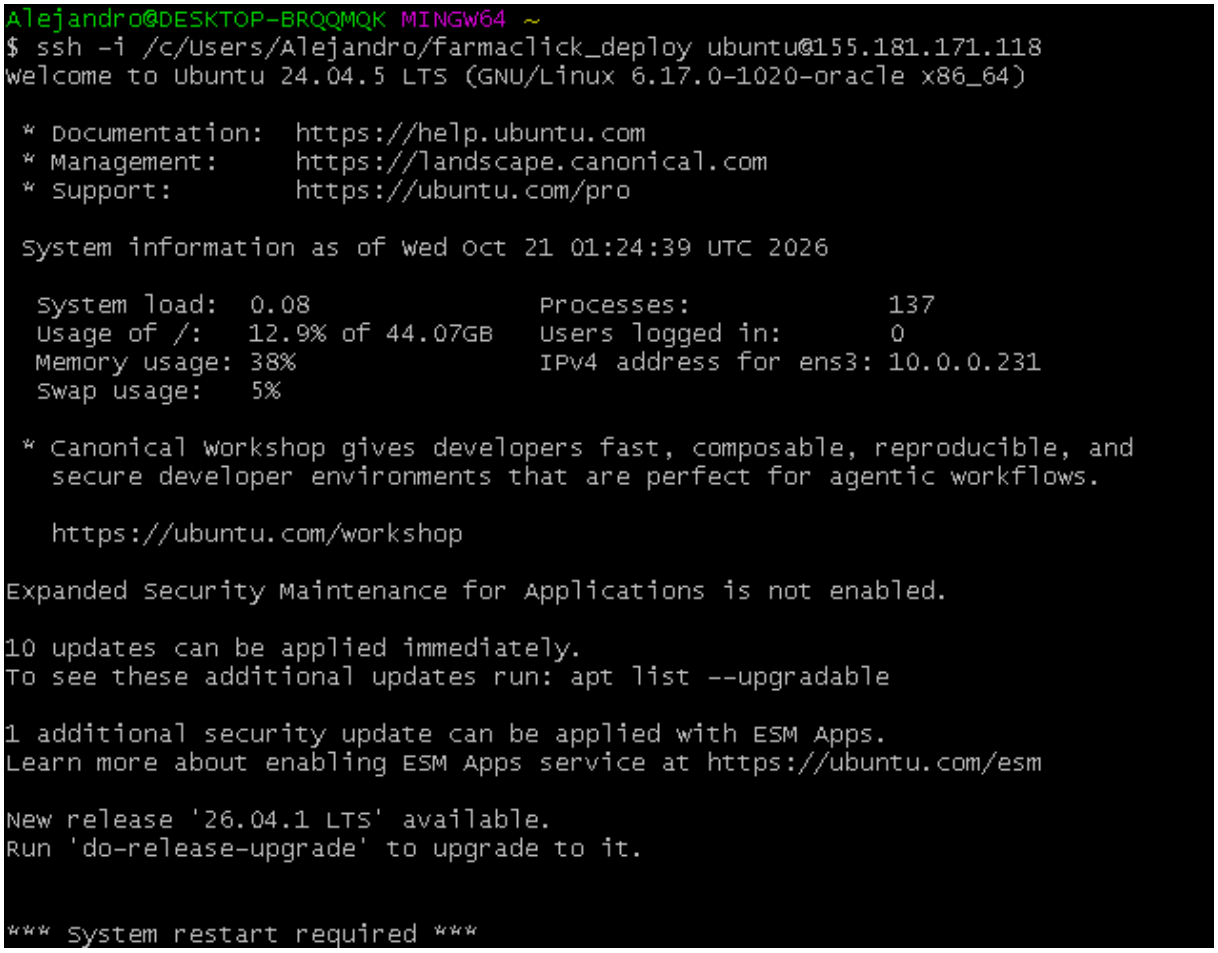


Figura 58 - OBS-01_vm_dev_20261020.png

VM de dev (Ubuntu 24.04.5 LTS): 10 actualizaciones pendientes, 1 adicional de seguridad (ESM) y aviso "System restart required". Memoria 38 %, disco 12,9 %.

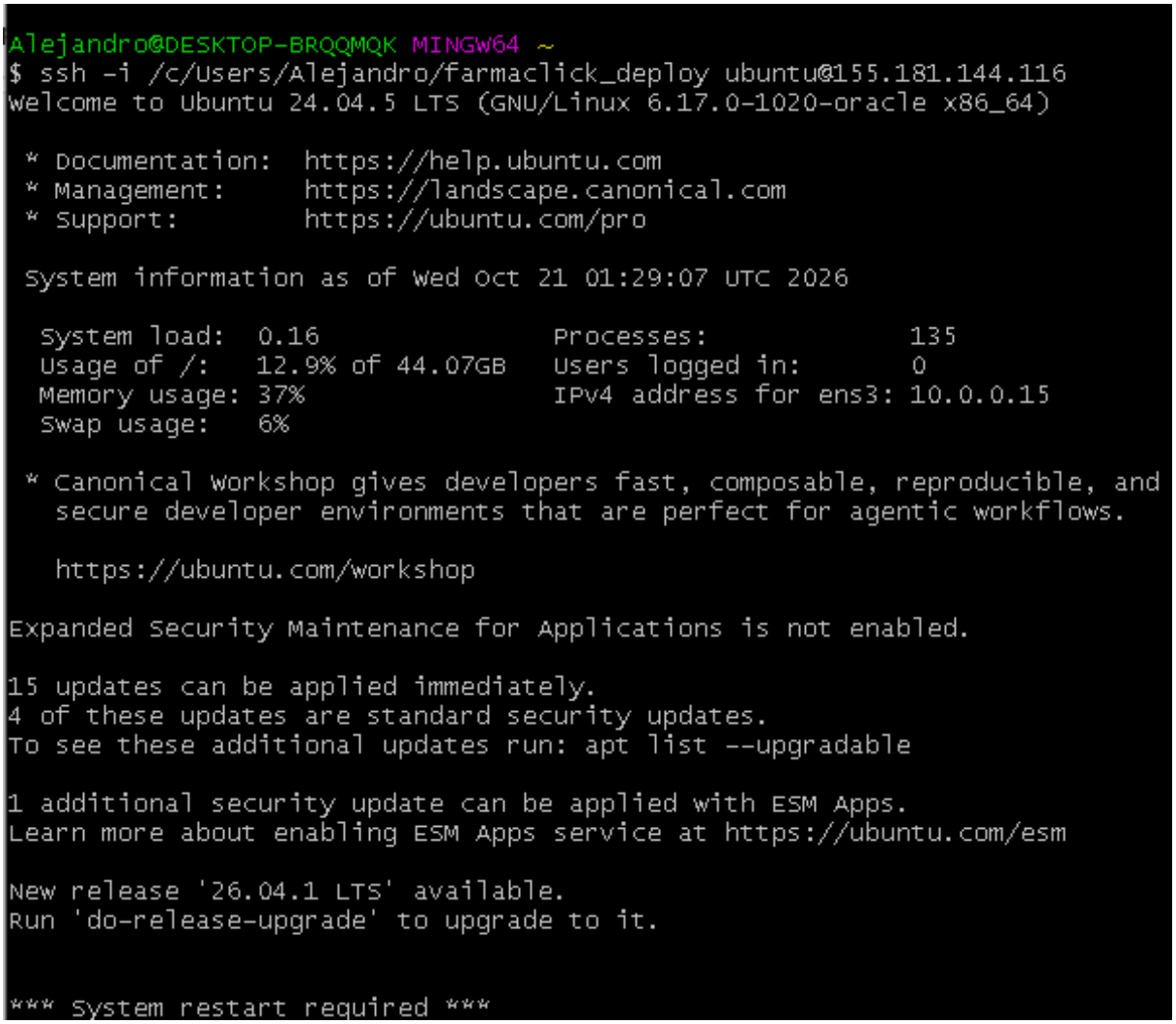


Figura 59 - OBS-01_vm_prod_20261020.png

VM de producción (Ubuntu 24.04.5 LTS): 15 actualizaciones pendientes, 4 de ellas de seguridad estándar, 1 adicional de seguridad (ESM) y aviso "System restart required". Memoria 37 %, disco 12,9 %.

7. Pruebas en la réplica local de la rama dev (17-10-2026)

Ejecución de Víctor Rubilar Inostroza sobre una réplica local de la rama dev (PostgreSQL 16 y Node 22): réplica de los jobs de la integración continua (esquema, backend, frontend y seguridad) y de las pruebas de humo, seguridad y carga. Cada captura muestra en su encabezado el comando ejecutado y la hora. Complementan las ejecuciones en dev y en producción del 20-10-2026 (secciones 2 a 5).

Integración continua (réplica de los jobs)



Figura 60 - ESQ-01_20261017.png

Job esquema (17-10-2026 20:40, PostgreSQL 16.15): instalacion_completa.sql termina sin errores (código de salida 0); las diez migraciones se vuelven a ejecutar sin fallar (idempotencia); 39 tablas en public y las 39 con RLS.

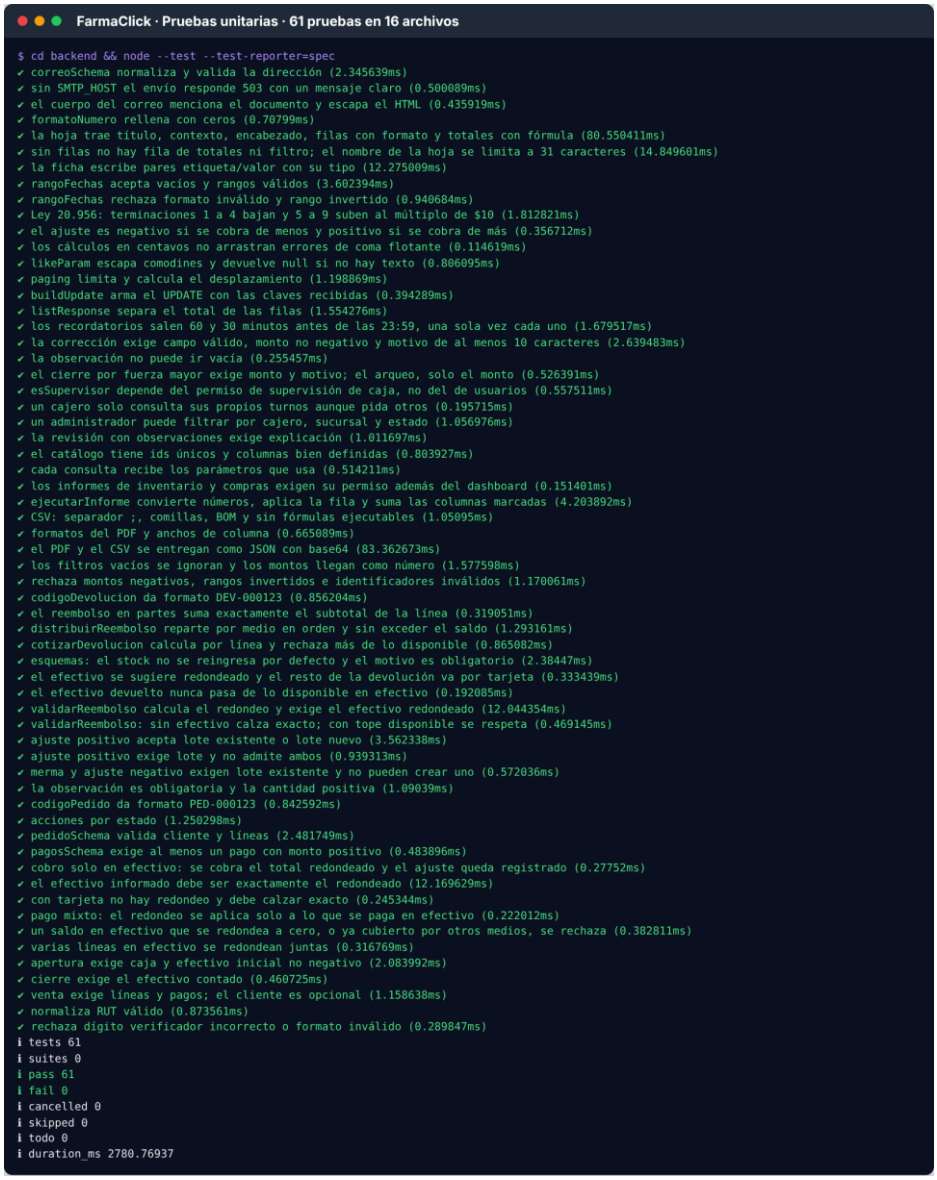


Figura 61 - `UNIT-01_20261017.png`

Job backend: node --test del backend, 61 pruebas en 16 archivos; 61 aprobadas, 0 fallidas, 0 canceladas y 0 omitidas, en 2,78 s (sección 3 del plan).



Figura 62 - FRONT-01_20261017.png

Job frontend: npm ci y vite build; 92 módulos transformados y compilación en 494 ms, sin errores.

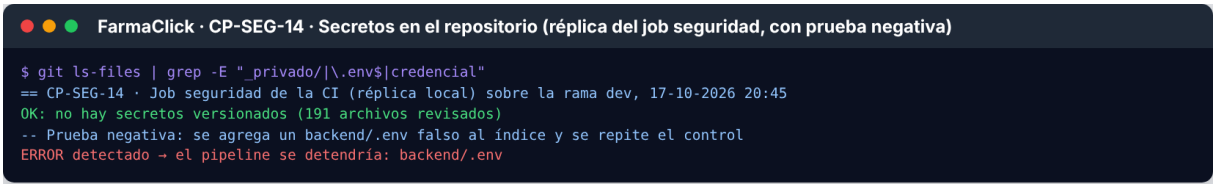


Figura 63 - CP-SEG-14_20261017.png

Job seguridad (17-10-2026 20:45): el control no encuentra secretos versionados (191 archivos revisados). En la prueba negativa se agrega un backend/.env falso al índice y el control lo detecta: "el pipeline se detendría".

Humo y seguridad de la API

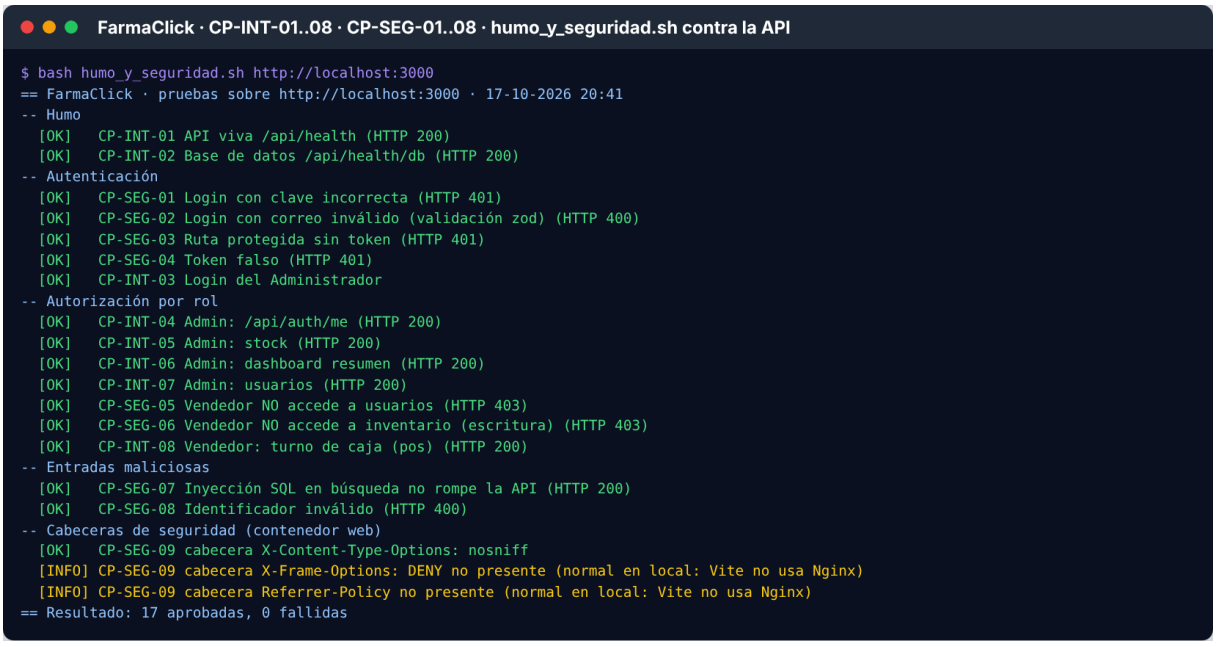


Figura 64 - HUMO-API_20261017.png

humo_y_seguridad.sh contra la API local (http://localhost:3000, 17-10-2026 20:41): 17 aprobadas, 0 fallidas. X-Frame-Options y Referrer-Policy salen como informativas porque Vite no usa Nginx.

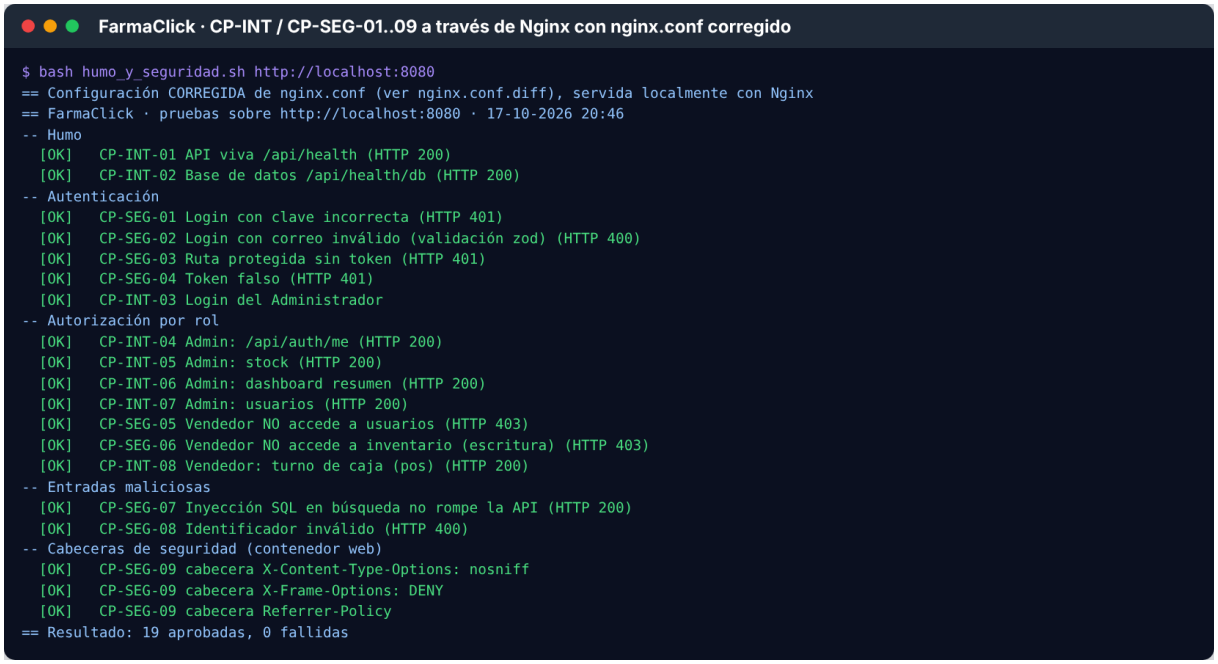


Figura 65 - HUMO-NGINX_20261017.png

El mismo script a través de Nginx local (http://localhost:8080, 20:46) con el nginx.conf corregido: 19 aprobadas, 0 fallidas, con las tres cabeceras de CP-SEG-09 presentes.



Figura 66 - CP-SEG-09_20261017_DEFECTO.png

Cabeceras de seguridad por ruta (20:47). Con el nginx.conf de la rama dev, /, /login y /assets/ no traen X-Content-Type-Options, X-Frame-Options ni Referrer-Policy y solo /api/health las trae; con add_header repetido en /assets/ e /index.html, las cuatro rutas las traen. Es el mismo defecto que se confirma en dev el 20-10-2026 (sección 2).

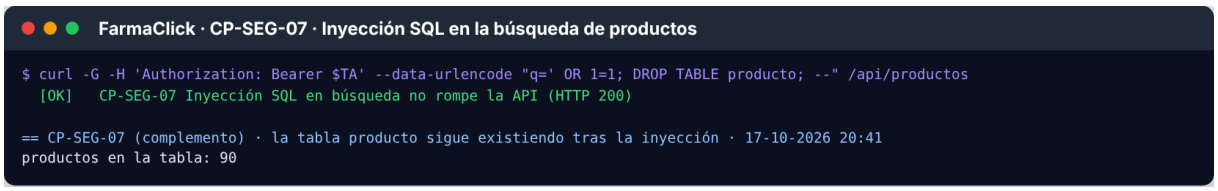


Figura 67 - CP-SEG-07_20261017.png

Inyección SQL en la búsqueda de productos (q=' OR 1=1; DROP TABLE producto; --): la API responde HTTP 200 y la tabla producto sigue existiendo con sus 90 productos (20:41).



Figura 68 - CP-SEG-10_20261017.png

Fuerza bruta en el login: los intentos 1 a 20 con clave incorrecta responden HTTP 401 y el intento 21 responde HTTP 429 "Demasiados intentos. Intente nuevamente en unos minutos." (límite de 20 por ventana de 15 minutos).

Dependencias, base de datos y rendimiento

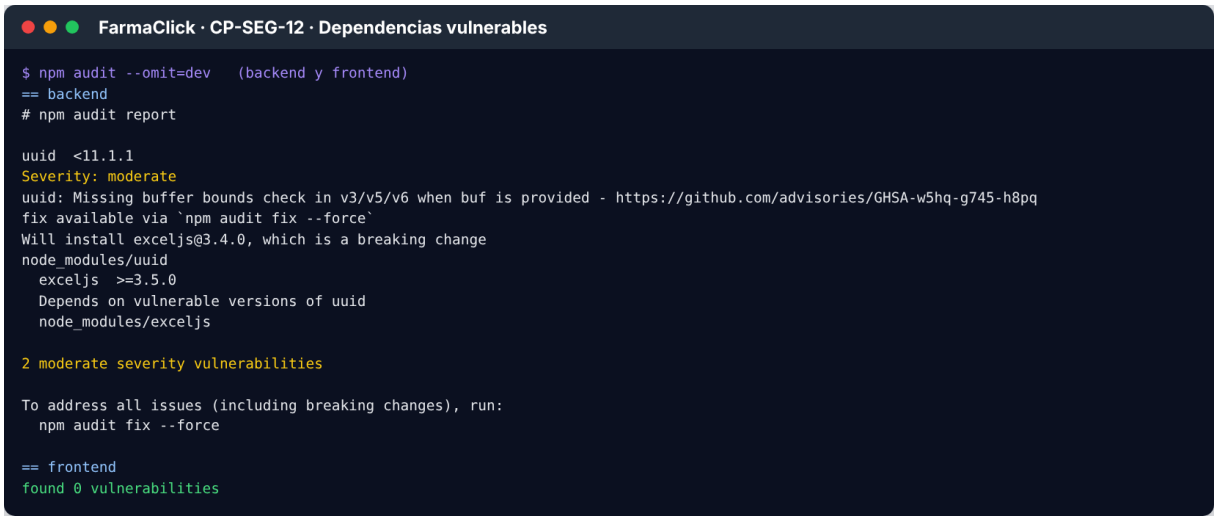


Figura 69 - CP-SEG-12_20261017.png

npm audit --omit=dev: backend con 2 vulnerabilidades moderadas (uuid anterior a 11.1.1, por exceljs) y frontend con 0.

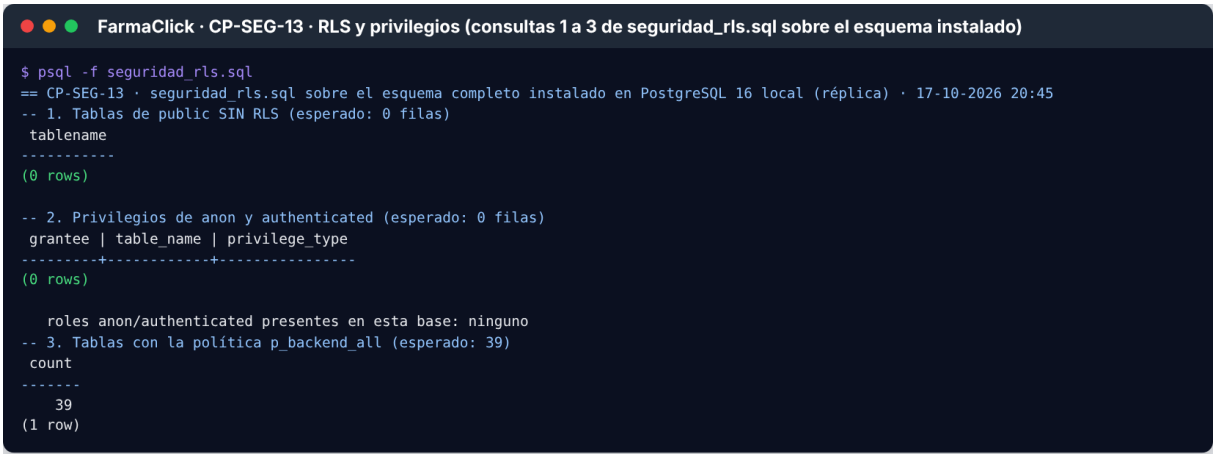


Figura 70 - CP-SEG-13_20261017_LOCAL.png

seguridad_rls.sql, consultas 1 a 3, sobre el esquema completo en PostgreSQL 16 local: 0 tablas sin RLS, 0 privilegios para anon y authenticated (esos roles no existen en la réplica) y 39 tablas con la política p_backend_all. La consulta 4 (tareas programadas) solo aplica en dev y producción (sección 5 de este anexo).

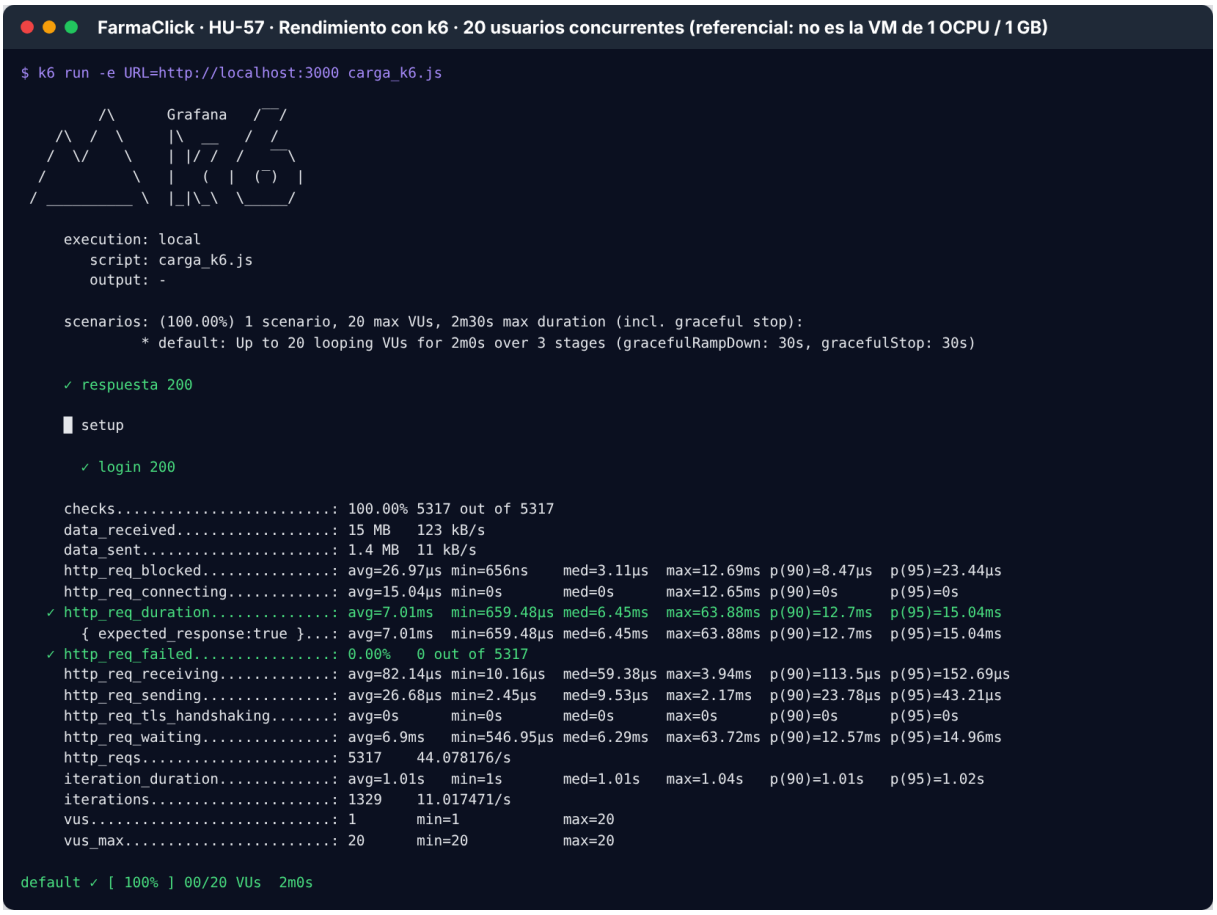


Figura 71 - HU-57_K6_20261017_LOCAL.png

k6 con 20 usuarios concurrentes contra la API local, 2 minutos: 5.317 solicitudes, 0,00 % fallidas, p(95) de 15,04 ms. Es referencial: no corresponde a la VM de 1 OCPU y 1 GB, cuya medición es la de dev y producción (sección 4).

8. Archivos de texto y reportes

Salidas completas de las herramientas, guardadas junto a las capturas con el nombre indicado.

Archivo	Contenido	Caso
humo_dev_antes_20261020.txt	Salida del script en dev antes de la corrección de nginx.conf: 16 aprobadas, 3 informativas	CP-SEG-09
humo_dev.txt	Salida del script en dev tras el despliegue: 19 aprobadas, 0 fallidas	CP-INT-01 a 08, CP-SEG-01 a 09
humo_prod.txt	Salida del script en producción: 19 aprobadas, 0 fallidas	CP-INT-01 a 08, CP-SEG-01 a 09
k6_dev.txt	Resumen completo de k6 en dev: p(95) 705,35 ms; 0,00 % de fallos (0 de 3.589)	HU-57
k6_prod.txt	Resumen completo de k6 en producción: p(95) 744,51 ms; 0,00 % de fallos (0 de 3.553)	HU-57
npm_audit_api_20261020.txt	npm audit --omit=dev del backend: 2 vulnerabilidades moderadas (uuid vía exceljs)	CP-SEG-12
npm_audit_web_20261020.txt	npm audit --omit=dev del frontend: 0 vulnerabilidades	CP-SEG-12
CP-SEG-11_20261020_reporte.html	Reporte de ZAP 2.17.0 (plantilla traditional-html)	CP-SEG-11
CP-SEG-11_20261020_reporte.json	El mismo reporte en JSON (11 alertas: 0 altas, 1 media, 5 bajas, 5 informativas)	CP-SEG-11
CP-SEG-11_20261020_plan_zap.yaml	Plan de automatización de ZAP generado en la ejecución	CP-SEG-11

9. Evidencias por incorporar

Casos del DOC-08 cuya evidencia aún no existe porque la prueba todavía no se ejecuta.

Caso	Prueba	Evidencia prevista
CP-WEB-01 a 15	Tienda en línea (Sprints 5 a 7)	CP-WEB-NN_AAAAMMDD.png